

Failure-Routing in AI/ML Python Except-Handlers: Prevalence, Labels, and a Predicate Refinement That Did Not Help

Yufei Yang Chen*

School of Cyber Science and Technology, Sun Yat-sen University, Shenzhen, China
fei76161@gmail.com

Abstract

Exception handlers that turn a failure into a success-shaped value — an LLM judge outage becoming a legitimate `0.0` — yield wrong answers with no crash and no log. We call this *failure-routing* and study the part a syntactic tool can see: failures routed inside an `except` handler. A six-rule AST detector over eight pinned AI/ML packages reports 621 findings in the 524,229 lines it scans; 366 (58.9%) lie outside the union of four syntactic linters, which reaches 0 of the 19 `contextlib.suppress` findings.

We then replaced the predicate “the handler returned a constant” with the one the definition asks for: “the failure became a value the caller cannot distinguish from success, and that is not the function’s contract”. Findings fell to 476, but the share the four linters already reach *rose*, 41.1% → 52.9%; 155 of the 184 dropped sites were linter-invisible. Over 140 labels the split runs against us: findings no linter reaches carry 1 defect in 56 (1.8%, 0.3–9.4), those linters reach carry 12 in 48 (25.0%, 14.9–38.8). The 12 that linters reach are all bare `except:`, which `flake8`’s E722 flags in 134 candidates corpus-wide — a search space $4.6\times$ smaller than ours at equal recall.

The labels are weak: LLM agents, not humans, wrote them, and the frozen 12 defects are three copy-paste families, so the cluster-level rate is 4.4% (1.5–12.2) against the 15.0% observation-level one. “Maintainers fixed it, so it was real” also fails structurally: labelling, spontaneous repair (13/478 sites, 2.7%) and reaction when told (16/43, 37.2%) count differently constituted populations — quantified non-identifiability, not impossibility. Recall is 3 of 14 ground-truth defects; 9 of 14 route failure outside any handler. Such detectors are search-space reducers with human adjudication, not oracles.

1 Introduction

Most software failures announce themselves. An exception propagates, a process exits, a stack trace reaches a log. The failures this paper studies do none of this. A handler catches a timeout from a model API and returns `0.0`, and the caller cannot distinguish that from a model that genuinely scored zero. A decode error is caught and an empty string returned, and the code downstream sees a document with no content rather than one that failed to load. Execution continues, the caller receives a value of the expected type, and a wrong answer proceeds in the shape of a right one. We call this *failure-routing*: the handler does not merely swallow the failure, it routes it into the success path. This paper studies the subfamily a syntactic tool can see — failures routed inside an `except` handler.

The consequence is that the usual evidence of a defect is missing by construction. A crash produces a bug report; a plausible wrong number rarely produces one. Nobody files the issue, nobody writes the regression test, and the standard warrant for a static-analysis finding — that a maintainer read it and fixed it — is least available exactly where the pattern is most dangerous. Detecting these handlers is the easy half of the problem. Establishing that what we detected are defects is the hard half, and it is the half we do not fully solve.

This work began with a narrower observation. A widely used Python linter recommends a refactoring that moves the pattern outside the detection scope of every linter we tested, including the one that recommends it.

***Disclosure.** The author of this paper is also the author of `failroute`, the detector evaluated here, and of the `semgrep` rule reported in the RQ1 coverage measurement. Results unfavourable to the detector are reported alongside the favourable ones; see in particular the RQ3 recall audit and RQ5, where a refinement of the detector’s own predicate is measured against a one-flag linter baseline and loses.

The SIM105 observation.

- `ruff`'s SIM105 rule recommends rewriting `try/except/pass` into `contextlib.suppress(...)`. The two forms are semantically identical.
- After the rewrite, the construct is out of reach of the linters we tested, and not only of the rule sets we happened to select: in our corpus all 19 `contextlib.suppress` findings are invisible to the union of `ruff`, `bandit`, `pylint` and `flake8+bugbear`, and enabling every one of `ruff`'s 969 rules, or `pylint`'s full default message set, adds no rule that reports it (Section 4.2). A `semgrep` rule *we wrote* covers 18 of the 19; citing it requires stating the rule is ours.
- A widely adopted refactoring therefore moves an entire defect shape outside the detection scope of the tools while leaving its runtime consequences unchanged.

Research questions.

- **RQ1** How prevalent is except-handler failure-routing in AI/ML Python, and how much of it do the syntactic linters practitioners already run reach? (Section 4.2)
- **RQ2** What fraction of the detector's findings are genuine defects, as opposed to deliberate contracts or tool artefacts? (Section 4.3)
- **RQ3** What fraction of known ground-truth defects does the detector reach, and how much of the phenomenon can *any* handler-shaped detector reach? (Section 4.4)
- **RQ4** What does systematic labelling of findings do to the detector itself? (Section 4.6)
- **RQ5** What does replacing the detector's predicate with the criterion the definition actually states buy — in findings, in coverage novelty, and in defects? (Section 4.7)

The methodological centre of the paper sits between RQ2 and RQ3: once the answer to RQ2 is unfavourable, what evidence could possibly settle whether the undetected remainder is real (Section 4.5)? RQ5 asks the question the first four leave open. RQ1 measures how much of the family the detector reaches that the linters do not, and RQ2 measures how defective the detector's output is, but neither asks whether those are the *same* findings. They are not, and the direction of the mismatch is this paper's negative result.

Contributions.

1. A taxonomy of six failure-routing shapes and an AST detector for them (Section 2).
2. A reproducible prevalence and cross-tool coverage measurement over 8 pinned packages (Section 4.2).
3. A labelled stratified sample ($n = 80$) giving a precision estimate for this detector family on real code (Section 4.3). The estimate is unfavourable to the tool, and the labelling was performed by LLM agents; both facts are disclosed and analysed rather than buried.
4. A tri-source triangulation for defect families where standard validation fails structurally (Section 4.5) — and a quantified non-identifiability result: its three arms count differently constituted populations, so no rate is common to them, and no matched-population substitute exists. We specify the datum that would settle the question.
5. A recall audit against maintainer-merged fixes (Section 4.4) that doubles as a construct-validity measurement: 64.3% of ground-truth defects do not route through an except-handler at all.
6. Evidence that systematic labelling is itself a detector-improvement method: it exposed a defect that accounted for 100% of one rule's real-world findings (Section 4.6).
7. A negative result on predicate refinement, with the crosstab that produces it (Section 4.7). Replacing “the handler returned a constant” with the definition's own criterion cut findings from 621 to 476 and *raised* the share four off-the-shelf linters already reach, from 41.1% to 52.9%. Over 140 labels the findings no linter reaches carry 1 defect in 56 (1.8%, Wilson 0.3–9.4) while the findings linters do reach carry 12 in 48 (25.0%, 14.9–38.8). The novelty the detector claimed and the defects it found were largely disjoint sets, and refining the predicate widened the gap rather than closing it.
8. A trivial baseline for this family, which earlier versions of this paper did not run: `flake8 -select E722` reduces the same corpus to 134 candidates and contains all 12 confirmed defects — a $4.63\times$ smaller reading task than the detector's 621, at equal recall on that label set (Section 4.7).

2 The pattern family

Six shapes, all reducible to “*a failure became a value the caller cannot distinguish from success*”, are listed in Table 1. The taxonomy is defined by the semantics of the Python constructs involved rather than fitted to the corpus studied here: four of the six shapes account for all 621 findings reported in

Section 4.2, and the two that never fire on this corpus are retained because a shape’s absence from one corpus is not evidence that the shape does not occur. Both are exercised by the tool’s unit corpus.

Table 1: The six failure-routing shapes.

Rule	Shape	Consequence
no-action	except ...: pass	caller never learns the operation failed
silent-fallback	handler returns/assigns a constant without re-raising	judge outage becomes a legitimate 0.0
masked-exception	catch-all conditionally re-raises <i>and</i> falls back to a constant	outcome depends on which branch ran
silent-suppress	with contextlib.suppress(...)	same semantics as except +discard; invisible to the linters we tested
implicit-fallback	handler neither re-raises, returns, nor records — falls through to implicit None	“did nothing” becomes a legitimate None
name-shadowing	except E as e: rebinds e inside the handler	Python deletes the binding on exit → NameError ; original exception lost

3 The detector

The tool is the instrument, not the subject, so we describe it only to the extent needed to interpret the study. **failroute** 0.8.0 parses each file to an AST and applies six rules through a shared registry, emitting text, JSON or SARIF; individual rules can be disabled per project under `[tool.failroute]`.

Unit of analysis. One finding is one **except** handler — or, for the **silent-suppress** rule, one `contextlib.suppress` statement — reported at the line where it starts. Findings are sorted by line, with a stable per-handler registry order for findings that share a line, so the output order is deterministic.

What counts as silence. A handler is treated as *recording* the failure, and therefore as not routing it, if its body re-raises; calls `exit` or `_exit`; calls `warnings.warn` or `warnings.warn_explicit`; or calls a logger-like name. Two properties of that test matter for reading Section 4.3, and an earlier version of this paragraph stated neither of them correctly.

First, the test is *not* uniform across handler kinds. A **catch-all** handler (bare `except:` or `except Exception:`) must call a method named in {`error`, `warning`, `warn`, `exception`, `critical`, `fatal`}; a **typed** handler qualifies on *any* method of a logger-like object, `debug` and `info` included — and, because the test matches the object rather than the method’s meaning, on method names that are not logging calls at all. `capture_exception` on a logger-like object also qualifies. A bare `print()` never does. So the unqualified claim this paragraph used to make — that `logger.debug()` does not silence a handler — holds only for catch-all handlers and is false for typed ones. The asymmetry is deliberate: a caught type is itself a record of the failure its author anticipated. Section 4.7 shows the asymmetry is load-bearing, because every defect in the frozen sample sits in a bare handler — it falls through the strict half of this test, not the lenient half.

Second, the test is not global. Only **silent-fallback** and **implicit-fallback** consult it; **no-action**, **masked-exception** and **name-shadowing** report without asking whether the handler recorded anything.

“Logger-like” means a base-name list (`logger`, `logging`, `log`, `_logger`, `_log`, `sentry_sdk`) plus a suffix heuristic, since real codebases name loggers `audit_logger`, `err_log` and `self._log`. Handler bodies are traversed through control flow but *not* into nested function, lambda or class bodies, so a `return None` inside a callback defined in a handler does not silence it.

What counts as a fallback value. A fixed constant set (`None`, `False`, `0`, `0.0`, `""`, `[]`, `{}`, `()`), whose ambiguous members (`True`, `1`, `1.0`) are marked as such because they are legitimate in boolean scorers, plus namespace-qualified sentinels such as `Status.UNKNOWN` and any project-specific values configured under `[tool.failroute]`. Bare names are deliberately not matched, so `return result` can never fire.

Exemptions. Three gates remove a site before any rule runs. The first is the caught type: absorbing `KeyboardInterrupt`, `SystemExit` or `GeneratorExit` is how a process is meant to end, and absorbing `StopIteration`, `StopAsyncIteration` or `CancelledError` is the documented iterator and cancellation idiom, so a handler catching only those is exempt — and a tuple handler is exempt only when every member is. The second is an opt-out marker in the handler’s own lines: `# failroute: ignore` or `# pragma: no cover`. The third is configuration: a rule disabled under `[tool.failroute]` never fires. All three gates are applied once, in the dispatcher, rather than re-implemented per rule.

The heuristics deliberately err on the side of reporting: a finding is meant to be worth a look, not to be a verdict. That design choice is part of why the precision measured in Section 4.3 is what it is.

Quality gates. A 158-test suite green across a 3 OS $\times$ 5 Python-version CI matrix (Ubuntu, macOS, Windows; Python 3.9–3.13), `mypy -strict`, and a hand-labelled unit corpus (v6 at the pinned tag, 68 samples: 36 positive / 32 negative) whose labels were written independently of tool output, held to precision = recall = 1.0 in CI.

Construct validity of the 1.0 figure. That 1.0 is evidence the detector matches its own specification, **not** evidence it finds real defects. Section 4.3 is the external-validity measurement, and Section 4.4 bounds how much of the phenomenon the handler-shaped operationalisation can reach at all.

4 Study

Statistical reporting. Two-sided intervals are Wilson score intervals with $z = 1.959964$; cells with a zero numerator additionally carry the exact one-sided 95% Clopper–Pearson upper bound $1 - \alpha^{1/n}$, and are labelled as such wherever they appear. The recorded cells — every interval quoted for the labelled sample, the per-package and per-rule breakdowns, the four-tool union, the recall audit and the triangulation — are produced by `tools/compute_intervals.py` and stored in `paper/intervals.json`; the five-tool union interval is the one figure derived from the same formula outside that file. Several denominators below are complete enumerations of a finite set rather than samples — all 621 findings, all 478 labelled tracked sites (the subset of the 2,128 the pipeline could label, Section 4.5), all 14 in-scope fixes, all 43 family PRs — so their intervals are read as *superpopulation* intervals: uncertainty about the rate in the wider AI/ML population that the corpus and the ledgers stand for, not sampling error inside the enumeration. That wider population is not a neutral one, and the two statements belong together: the eight packages were chosen because the author had prior contribution history in them (Section 6), so these intervals quantify uncertainty around a convenience-selected corpus rather than around AI/ML Python at large.

4.1 Corpus

Eight AI/ML packages fetched as pinned PyPI source distributions (not git clones), each recorded with URL, SHA-256, upload time and extracted tree hash in `paper/corpus-lock.json`. Table 2 lists them. Together the eight sdists hold 2,354 `.py` files and 563,270 lines; the scan roots the detector actually reads hold 2,124 files and 524,229 lines, and every prevalence figure in this paper is a ratio over the latter. Fetching is pinned rather than merely scripted: `tools/fetch_corpus.py` resolves each package to the version recorded in `paper/corpus-manifest.json`, checks the downloaded archive’s SHA-256 against the same manifest, and exits non-zero on mismatch, so a re-fetch either reproduces these inputs or fails loudly. A fresh fetch into a clean directory on 2026-09-02 reproduced all eight archives byte-identically (8/8 SHA-256 matches against `corpus-lock.json`).

A second, style-opposite corpus tests whether the headline comparison survives outside bare-`except` code. Eight infrastructure packages were fetched as pinned PyPI sdists (URL, SHA-256, upload time and tree hash in `paper/corpus-lock-control.json`, same schema as above): `attrs` 26.1.0, `httpx` 0.28.1, `requests` 2.34.2 and `urllib3` 2.7.0 (the four zero-bare-`except` packages of Section 4.8), plus `click` 8.5.0 (CLI), `pydantic` 2.13.5 (validation), `anyio` 4.15.1 (concurrency) and `msgpack` 1.2.2 (serialization) — chosen for domain diversity before any scan ran, explicitly avoiding the HTTP-client stack that three of the first four share. Only each package body is scanned (scan roots recorded in the lock file), the same definition as above. Section 4.8 reports the comparison.

Table 2: Pinned corpus. Per-package counts are the files *inside each scan root* — the subtree the detector actually scans — so the column sums to the total shown (2,124 .py files / 524,229 lines). The eight pinned sdist contains **2,354** .py files / **563,270** lines in total; the difference is content outside the scan roots (tests, examples, vendored code).

Package	Version	Scan root	.py files	Lines
inspect_ai	0.3.260	src/inspect_ai	755	198,351
pydantic_ai_slim	2.36.0	.	298	119,534
deepteam	1.0.9	deepteam	588	71,305
trl	1.12.0	trl	155	65,727
garak	0.16.0	garak	201	38,328
smolagents	1.26.0	src/smolagents	20	13,355
uqlm	0.6.5	uqlm	91	12,605
fickling	0.1.12	fickling	16	5,024
Total (scanned)			2,124	524,229

4.2 RQ1 — Prevalence and cross-tool coverage

`failroute` (v0.8.0) reports **621** findings. Baselines were run on the *same* pinned trees; Table 3 lists the tools, their versions and the rule sets they were invoked with.

Matching protocol. Each baseline was invoked with only the rules that address this family — `ruff` S110/S112, `bandit` B110/B112, `pylint` W0702/W0703/W0705/W0706, `flake8` E722 with `bugbear` B001/B017 — and every report was reduced to a (file, line) pair. A `failroute` finding counts as *covered* by a baseline when that baseline reported any of its selected rules in the same file within ± 1 line of it (TOL = 1 in `tools/coverage_union.py`), and as covered by the *union* when any baseline covers it. Co-location is deliberately a weak criterion — it asks whether a tool flagged the same handler, not whether it expressed the same property — and the caveat at the end of this subsection states what that costs.

A blind spot in our own baseline harness, found by review and fixed. An earlier version of this measurement passed each scan root to `pylint` as a single directory argument. `pylint` walks a directory as a *package* and does not descend into one with no `__init__.py`, so every module under such a directory is silently never analysed — no message, no error, exit 0. Here 152 of the 2,124 scanned files (7.2%) sit under one (`inspect_ai` 123, `deepteam` 20, `garak` 9), and RQ1’s exact selection emits 34 messages across 20 of them that the directory invocation reported as zero. Handing `pylint` the file list recovers them and perturbs nothing else: on the files it already reached, the two invocations agree message for message (0 lost, 0 gained, per package), so the correction is a pure addition to the baseline. Every figure in this paper uses the corrected invocation, and it moves the four-linter union from 250 to 255 of 621 and `failroute`-only from 371 to 366 — it *reduces* the detector’s measured novelty, which is the direction a self-inflicted error should be reported in. The other three baselines have no equivalent blind spot: `ruff`, `bandit` and `flake8` are filesystem walkers, and over those same 152 files their directory and explicit-file invocations return identical hit sets (6,879, 104 and 2,375 messages respectively, both ways). The control corpus of Section 4.8 contains no `__init__`-less directory at all (0 of 263 files), so it was never exposed. `-recursive=y` and `-init-hook` were both tested; neither recovers a single message.

One asymmetry in that rule list we disclose rather than defend: `pylint` is granted W0703 (broad `except`), whose direct `ruff` analogue BLE001 was *not* selected, so `ruff` was the only baseline denied its broad-`except` rule. Re-running with BLE001 added, `ruff`’s *own* co-located findings rise from 72 to 127 (410 findings in total rather than 76), but the four-tool union does not move: 255 of 621 and `failroute`-only 366 under either selection, because every finding BLE001 newly reaches is one `pylint`’s W0718 already reaches. `silent-suppress` stays at 0/19 either way, since BLE001 fires on `except` clauses and the shape in question has none. The asymmetry therefore costs the union nothing and bears only on the per-tool comparison below; we keep the narrower selection as the headline because that is what the publicly tagged artefact set reproduces. The symmetric run is `tools/coverage_union.py -ruff-select S110,S112,BLE001`, and its output is committed as `bench/corpus-coverage-union-ruff-ble001.json`.

Table 3: Cross-tool comparison on the pinned corpus. The `semgrep` row is *not* a shipped-rule baseline: its rule set (`tools/semgrep-rules/exception-handling.yaml`) was written by us, so it shows what a syntactic-pattern engine *can* express given rules, not what users get by default. +19 is the number of `failroute` findings newly co-located once `semgrep` is added to the union (mostly the `contextlib.suppress` shape: 18 of 19). Versions are those installed in the reproduction environment and are the versions that produced the committed artefacts. Two provenance notes. `pyproject.toml` pins `ruff==0.16.5`, one patch above the 0.16.4 measured here; we could not test 0.16.5, but 0.16.0 and 0.16.4 produce *set-identical* hits for both rule selections (76 findings for S110/S112 and 410 for S110/S112/BLE001), so the row is stable across the patch releases we could compare. And `semgrep` does not appear in `pyproject.toml` at all: the five-tool row is a frozen artefact (`bench/corpus-coverage-union-5tool.json`), not a step the documented install reproduces.

Tool	Version	Rules	Findings	Co-located ± 1 line
failroute	0.8.0	all six	621	—
ruff	0.16.4	S110, S112	76	72
bandit	1.9.4	B110, B112	67	63
pylint	4.0.8	W0702, W0703, W0705, W0706	563	255
flake8+bugbear	7.3.0 / 25.11.29	E722, B001, B017	268	124
semgrep (our rules)	1.175.0	hand-written, 6 shapes	—	+19

Union of the four syntactic linters covers 255 of 621 (41.1%, 95% Wilson interval 37.3–45.0). failroute-only: 366 (58.9%). Adding our `semgrep` rules raises the union to 274 (44.1%, 40.3–48.1) and lowers the `failroute`-only count to 347 (55.9%). Table 4 breaks both figures down by rule and Figure 1 plots them.

Table 4: Coverage by rule; “Covered by 4” is the four shipped linters, “Covered by 5” adds our self-written `semgrep` rule. `implicit-fallback` and `name-shadowing` fire zero times on this corpus; they remain in the tool because the unit corpus exercises them. On `silent-suppress`: none of the four selected rule sets reports any of the 19 findings, and neither does `ruff` with all 969 of its rules enabled nor `pylint` with its full default message set — across the five files holding those 19, `ruff` emits 414 messages in 48 distinct rules and `pylint` 123 in 18, and the only ones falling within ± 1 line are line-length complaints (E501, `line-too-long`) on five of them, none a rule about a silenced failure. Only a rule we wrote reaches them (18/19).

Rule	Total	Covered by 4	Covered by 5	failroute-only vs 4-tool union
silent-fallback	386	180	181	206
no-action	213	72	72	141
silent-suppress	19	0	18	19
masked-exception	3	3	3	0
implicit-fallback	0	—	—	—
name-shadowing	0	—	—	—

Two observations that cut against the tool.

1. `pylint` is a stronger baseline than `ruff`, by a factor that depends on which `ruff` rules the comparison allows. Against `ruff`’s S110/S112 alone — the selection our own earlier benchmark used — the gap is $3.54\times$ (72 vs 255 co-located findings). Given `ruff`’s broad-except rule BLE001, symmetric to the W0703 `pylint` is granted here, it falls to $2.01\times$ (127 vs 255). A benchmark against `ruff` alone is therefore only as informative as the rule list it states: the $3.54\times$ figure is an artefact of a two-rule selection, and we quote it here to retract it rather than to use it.
2. `masked-exception` is fully covered. All 3 findings co-locate with a `pylint` broad-except warning. That rule contributes no coverage novelty here, and with $n = 3$ the 100% estimate is statistically meaningless (interval 43.9–100.0).

The baseline we should have run first. The union above is a *coverage* comparison: it asks which of the detector’s findings a linter also flags. It does not ask the prior question — how long a candidate list one trivial rule produces, and how many of the confirmed defects that list already contains. `flake8`

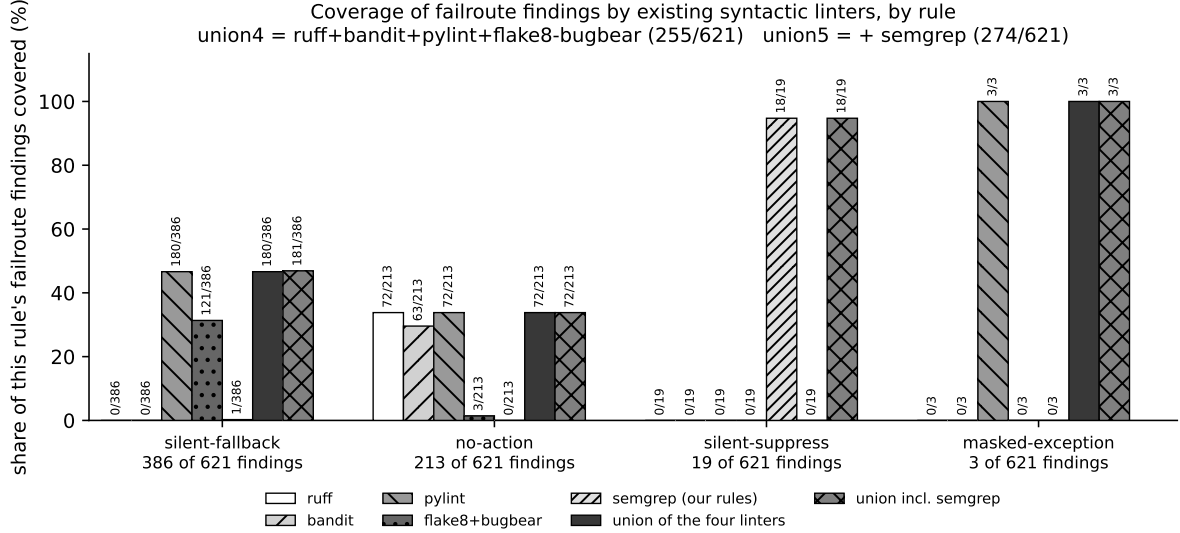


Figure 1: Per-rule coverage by tool, including the four-linter union and the five-tool union. **silent-suppress** is the one rule where the selected rule sets, **ruff**’s full 969-rule set and **pylint**’s full default set all return zero coverage.

-select E722 answers both, and the answer is unfavourable to this tool. Over the same eight scan roots **E722** reports **134** bare-except sites, and all **12** defects the labelling round confirmed (Section 4.3) are among them. The detector reports 621. A rule that costs one flag and no semantics therefore reaches the same 12 defects from a reading list **4.63**× shorter; against the refactored detector’s 476 findings (Section 4.7) the factor is **3.55**×. **E722**’s defect yield on its own list is 12/134 = 9.0% (Wilson 5.2–15.0), a complete enumeration, against the detector’s 12/80 = 15.0% on a stratified sample that is *not* a frame estimate (Section 4.3, Method) — so the two yields are not directly comparable, and the comparison that matters is list length at equal recall rather than yield.

ruff’s broad-except rule BLE001 is the natural companion and it does not work here: 334 candidates, **0** of the 12 defects, one-sided 95% upper bound 0.9%. BLE001 fires on **except Exception:** and not on bare **except:**, and every defect confirmed in the frozen sample is a bare handler. That asymmetry is the most useful single fact in this section: the defect-bearing members of this family are the ones the *least* sophisticated rule catches and the semantically broadest one misses, which is not the ordering a reader would predict from the coverage table above.

Both counts come from `tools/e722_baseline.py`, which fails loudly if either linter is unusable rather than reporting an empty hit set, and are committed as `bench/e722-baseline.json`; the intervals come from `tools/compute_intervals.py -rq5`.

Methodological caveat on “coverage”. Co-location at ± 1 line means a syntactic tool *flags the same handler*, **not** that it expresses the same property. **pylint** W0703 fires on **except Exception:** regardless of what the handler does; it does not distinguish “re-raises” from “returns 0.0”. 41.1% is therefore an *upper bound* on what the syntactic tools actually say about these handlers, and the share of findings whose *property* no linter expresses is larger than 58.9%. We report the conservative number.

Section 4.7 measures what that conservatism turns out to be worth, and the result does not favour the tool. The additional nominal novelty is concentrated in findings that are almost never defects: over 140 labels, the findings no linter co-locates with carry 1 defect in 56 (1.8%), while the findings a linter does co-locate with carry 12 in 48 (25.0%). So the bias is real in the direction stated — the linters are credited with more than they say — and its consequence runs the other way. A larger semantic-novelty share would be a larger share of deliberate contracts, not of defects, because the property that separates the two in this corpus is whether the handler is bare, and bare handlers are exactly what **E722** already lists.

4.3 RQ2 — What fraction are real defects?

Method. Stratified random sample over (rule $\times$ package), fixed seed (20260831), every stratum guaranteed ≥ 1 draw, remainder allocated proportionally. $n = 80$. The guarantee makes the allocation deliberately *non-proportional*: across the 19 strata of the frozen 649-finding frame the sampling fraction runs from 8.9% to 50%, so the unweighted share 12/80 is a property of the sample and not an unbiased estimate of the frame’s defect share. The draw itself was taken from the 659 frame, which carries four more strata — the **implicit-fallback** ones, one draw each — and every fraction and weight quoted here is measured against the 649 frame that survives in **paper/scan**, because a weighted estimator mixing the two would divide by sample items the frame no longer contains. Weighting each stratum by its frame size gives **20.0%** (130 expected defects in the frozen v0.7.0 finding frame); weighting by package instead gives 19.9%, so the granularity of the weighting does not matter, only that the design is respected. Weighting *raises* the estimate, because the single defect-bearing stratum (**silent-fallback** $\times$ **deepteam**, all 12 of its draws defective) was sampled at 9.2% while zero-defect strata were sampled at up to 50%. We report the unweighted shares in Table 5, since they are what the sample directly shows, and the weighted or package-specific estimate wherever a population inference is drawn (Sections 4.5 and 6). The draw is deterministic *given its input frame*: **tools/draw_sample.py** at that seed reproduces **paper/sample.jsonl** from the v0.7.0 finding set it was drawn from, and selects a different sample if it is run against the v0.8.0 frame — which is why the script is excluded from the reproduction path (Section 9). Each finding was labelled by reading the surrounding source in the pinned tree into one of three classes: **DEFECT** (the converted failure produces a wrong caller-visible outcome with no signal), **CONTRACT** (deliberate, and either documented, commented, or expressed in the return type), **FALSE POSITIVE** (the detector is wrong about the code).

Labelling was performed by LLM agents. Two rounds were run, both by LLM agents (not human raters), and they agreed on 80/80 items. We do not report this as label quality, and we do not claim the two rounds were independent: identical agreement between two runs of the same model family is evidence of *shared bias*, not of reliability, and nothing in the artefact set demonstrates independence beyond the two runs being separate. What is committed is both label sets — **paper/annotations.csv** (first round, rationales recorded in Chinese) and **paper/annotations-second-pass.csv** (second round, rationales in English) — so the agreement can be checked item by item rather than taken on trust. The sample remains useful as (a) a debugging instrument (Section 4.6) and (b) the consequence arm of the triangulation in Section 4.5, where its limits are part of the design.

Sampling frame. The draw was taken from the *v0.7.0 finding set* ($n = 659$). Two subsequent corrections changed the frame: labelling itself exposed the **implicit-fallback** bug whose 10 findings were all false ($659 \rightarrow 649$), and the v0.8.0 precision fixes removed 28 more ($649 \rightarrow 621$, Section 4.6). Of the 80 sampled coordinates, 72 survive in the 621 set. Of the 8 deleted items, 4 — the **implicit-fallback** findings — were labelled **FALSE POSITIVE** and 4 — those removed by the precision fixes — were labelled **CONTRACT**; *zero labelled DEFECT was lost*. The label proportions below therefore hold *within the v0.7.0 frame*, and the surviving sample is not random with respect to the 621 frame.

Result (v0.7.0 frame, LLM-labelled). Table 5 reports the three shares, Table 6 breaks them down by rule and Table 7 by package — the breakdown the triangulation in Section 4.5 has to respect, because the defect share turns out to be a property of packages rather than a corpus-wide constant.

All 12 defects are in deepteam. Across the other seven packages, 0 of 66 sampled findings were defects (pooled one-sided 95% upper bound 4.4%), the spread plotted in Figure 2.

The 12 defects are not 12 independent bugs. They are **three homogeneous families** replicated across metric classes:

1. **Silent criteria degradation (4/12).** try:

```
self.system_prompt = model.get_system_prompt()
except:
self.system_prompt = "". A custom or misconfigured LLM that lacks the method silently scores every subsequent case under empty criteria. (This family was reported upstream by the present author before the labelling pass, as confident-ai/deepteam#270 — an issue, not a pull request. It was still open, its single comment from a non-maintainer and no maintainer response, when this paper was prepared. It records the author’s own prior observation; it is not external validation of the label or of the tool.)
```


Table 5: RQ2 headline: the shares of the drawn sample. 12 of the 80 findings (15.0%, Wilson lower bound 8.8%) are defects. This is an *unweighted* sample share; because the design guarantees every stratum at least one draw, weighting each stratum by its frame size raises the estimate of the frame’s defect share to 20.0% (Method, above). All three shares are stated for the v0.7.0 sample frame. Restricting to the 76 of the 80 that are still findings in that frame — once the four **implicit-fallback** false positives are gone — the shares are $12/76 = 15.8\%$ DEFECT and $64/76 = 84.2\%$ CONTRACT with no false positive left: the labelling pass closed the loop on the one detector bug it found. The v0.8.0 frame retains 72 of the 80, as the sampling-frame paragraph above sets out.

Label	<i>n</i>	Share	95% Wilson interval
CONTRACT	64	80.0%	70.0–87.3
DEFECT	12	15.0%	8.8–24.4
FALSE POSITIVE	4	5.0%	2.0–12.2

Table 6: Labelling by rule. All 12 defects come from **silent-fallback** (24.5% of that rule’s sample, interval 14.6–38.1); all 4 false positives come from **implicit-fallback**.

Rule	<i>n</i>	DEFECT	CONTRACT	FALSE POS.
silent-fallback	49	12	37	0
no-action	23	0	23	0
implicit-fallback	4	0	0	4
silent-suppress	3	0	3	0
masked-exception	1	0	1	0

Table 7: Labelling by package. The “upper” column is the exact one-sided 95% Clopper–Pearson upper bound on the defect rate for zero-defect cells; small-*n* cells are wide and must not be read as strong evidence. The pooled row is the seven packages other than **deepteam**. This is the breakdown the triangulation of Section 4.5 has to respect: the defect share is a property of packages, not a corpus-wide constant.

Package	<i>n</i>	DEFECT	CONTRACT	FALSE POS. / defect bound
deepteam	14	12	1	1 FP; defect rate 85.7% (60.1–96.0)
inspect_ai	41	0	40	1 FP; upper 7.0%
pydantic_ai_slim	11	0	10	1 FP; upper 23.8%
trl	4	0	4	0; upper 52.7%
garak	3	0	3	0; upper 63.2%
fickling	3	0	2	1 FP; upper 63.2%
smolagents	2	0	2	0; upper 77.6%
uqlm	2	0	2	0; upper 77.6%
<i>all but deepteam</i>	66	0	63	3 FP; upper 4.4%

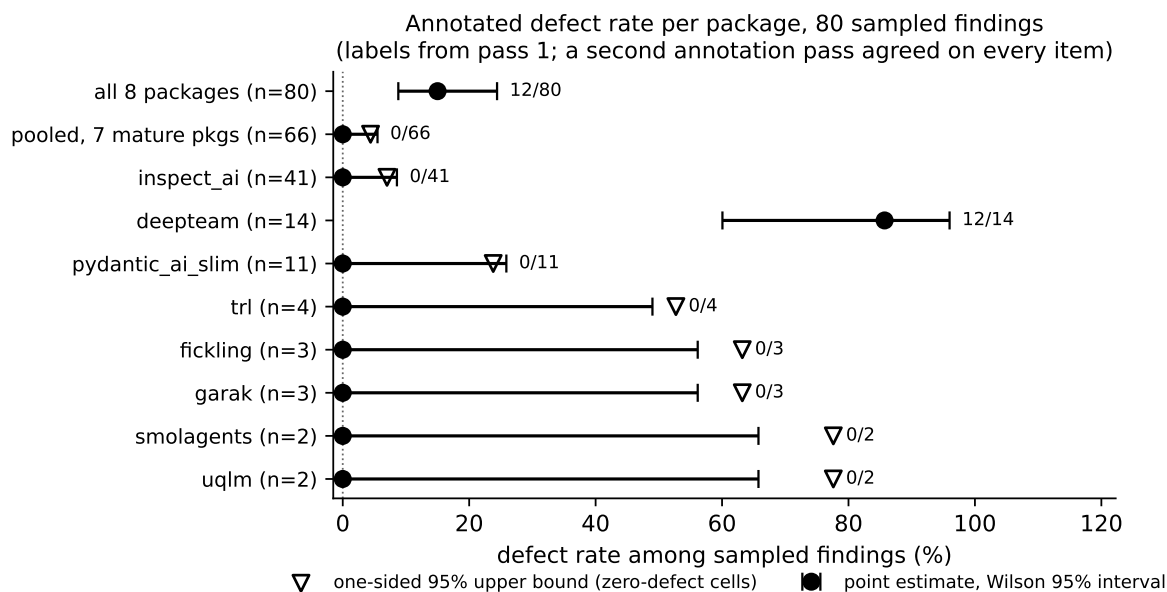


Figure 2: Measured defect rate per package with Wilson 95% intervals. Zero-defect cells are drawn as exact one-sided 95% Clopper–Pearson upper bounds (triangles). The visual point is the spread, not the ordering.

2. **Dead comparison (5/12).** `try: self.score == 1 except: self.success = False`. The guarded statement is a pure comparison expression that cannot raise, so the handler is dead code — and `self.success` is never assigned on the success path.
3. **Fail-open security verdict (3/12).** `is_vulnerable()` iterates results inside a `try`; on any error it returns `vulnerable = False`. In a red-teaming tool, “not vulnerable” is the most dangerous possible default: an infrastructure failure is converted into a clean security conclusion.

The defects are one handler shape, and it is the cheapest shape to lint. Classifying each labelled finding by the handler it sits in — parsed from the pinned corpus at the finding’s own line, not read off the labels’ prose (`tools/compute_intervals.py -rq5`) — the frozen sample of 80 splits into four strata: **13** bare `except:` handlers, of which **12 are defects** (92.3%, Wilson 66.7–98.6); **18** catch-all typed handlers (`except Exception:`), **0 defects**, one-sided 95% upper bound 15.3%; **46** narrow typed handlers, **0 defects**, **one-sided upper bound 6.3%**; and **3** `contextlib.suppress` sites, **0 defects**, upper bound 63.2% — a cell of three that is not evidence of anything and is listed only so the strata sum to 80.

The 6.3% is the bound that carries the argument, and it is worth saying why it is not tighter. Pooling the catch-all typed and narrow typed handlers into a single “typed” stratum gives $n = 64$ with 0 defects and an upper bound of 4.6%. We do not use it. The two strata are not equally exposed: `except Exception:` is precisely what `ruff`’s BLE001 and `pylint`’s W0718 already fire on, so those 18 observations are not part of the detector’s uncovered contribution at all, and folding them in buys a tighter bound by spending coverage novelty that was never claimed. Restricted to handlers that are both typed and invisible to those two rules, the bound is 6.3% at $n = 46$. The wider bound is the honest one.

What the clustering does to the 15.0%. The paragraph above says the 12 defects are three families. The statistic in Table 5 does not know that: a Wilson interval on 12/80 treats the 80 labels as 80 independent draws, and they are not. Clustering the sample by (package, enclosing function name) — the key that reproduces the three families exactly, with no judgement call about which copies belong together — leaves **3 defect-bearing clusters of 68**, that is **4.4%** (Wilson 1.5–12.2), against the observation-level 15.0% (8.8–24.4). The choice of clustering key is not cosmetic and we report the alternatives rather than the one that suits us: by exact signature string the same sample gives 5 of 71 = 7.0% (3.0–15.4), because the three `__init__` copies differ in their parameter lists; by (package, file,

function) it gives 12 of $78 = 15.4\%$, essentially unchanged, because each copy sits in its own file and that key does not capture the replication at all. We therefore quote 15.0% as *descriptive* — it is what the sample contains — and 4.4% as the estimate the sample is evidence for. The design-weighted 20.0% of the Method paragraph weights strata, not clusters, so it inherits the same dependence and corrects a different bias (non-proportional allocation); we have no weighting that corrects both, and we keep quoting it only where a frame-level inference is being drawn and say so there.

The pooled zero needs the same treatment. “All but **deepteam**”: 0 of 66, one-sided upper bound 4.4% ” also presumes 66 independent observations; at cluster level it is 0 of 63, upper bound **4.6%** . The correction moves that cell by 0.2 percentage points, which is the honest size of the effect where there is little to cluster — the non-**deepteam** labels are not replicated the way the defect-bearing ones are. Section 4.7 adds 60 further labels for a total of 140; at that size the cluster-level rate is 4 of $116 = 3.4\%$ (1.3–8.5) and the observation-level rate 13 of $140 = 9.3\%$ (5.5–15.2).

Conversely, the 64 contracts are overwhelmingly *deliberate and legible*: TUI widget lookups that may not be mounted, optional-dependency probes, idempotent cleanup in **finally**, and predicate functions whose **Optional/bool** return type *is* the contract. Many carry an explicit comment stating the intent (e.g. `inspect_ai`’s “fail open — better to skip the barrier than to hang teardown”).

Two findings in the sample are worth citing as **positive** examples of the discipline this paper argues for: `pydantic-ai`’s `is_private_ip` fails *closed* on an unparseable address (“Invalid IP address, treat as potentially dangerous” → **return True**), and its `_run_tool` explicitly routes a caught exception onto a queue *so that the consumer re-raises it* rather than letting it vanish.

4.4 RQ3 — Recall audit and construct validity

An unusual ground truth is available: upstream fixes in this defect family that the projects’ own maintainers reviewed and merged. Of the 75 pull requests authored by the present author that were merged *as of the 2026-09-01 measurement freeze*, **16** are failure-routing fixes — every exclusion adjudicated by reading the PR diff (52 earlier title-only judgements were re-checked against diffs in a dedicated pass; 49 stood, 3 flipped). For each family fix, the file was fetched at the merge commit’s *first parent* (i.e. immediately pre-fix) and scanned. Table 8 classifies the 16, and every pull request is cited with its repository owner so that the classification can be checked against the public record.

Table 8: Classification of the 16 family fixes (`paper/merged-pr-recall.csv`, all rows diff-read). “Handler-shape gap” means design-reachable: a shape outside the current six that could be expressed without changing the handler-level design.

	Class	<i>n</i>	Cases
Out of scope for recall		2	<code>microsoft/PyRIT#2460</code> , a TypeScript-side change (language scope); <code>cvs-health/uqlm#418</code> , a pure-additive <i>Python</i> fix whose pre-fix defect is a non-handler implicit-None contract violation the six rules do not cover by design
Detected		3	<code>cvs-health/uqlm#450</code> , <code>Ishannaik/agent-sweep#197</code> , <code>truera/trulens#2653</code>
Handler-shape gap		2	<code>UKGovernmentBEIS/inspect_ai#5068</code> (post-handler state mutation), <code>#4906</code> (tenacity <code>RetryError</code> masking) — both adjudicated as candidate patterns, not shipped
Non-handler routing		9	NaN values reaching aggregates, silently filtered lists, branch-level <code>Score(0.0)</code> returns, implicit-None contract violations, silently stripped characters, silently dropped symbols, laundered verdicts

Recall on the corrected denominator: 3 of $14 = 21.4\%$ (95% Wilson interval 7.6–47.6). The ceiling for *any* handler-shaped detector on this ground truth is 5 of $14 = 35.7\%$, because **9 of $14 = 64.3\%$ (38.8–83.7) of the defects route the failure outside any except-handler**. Figure 3 plots the split by defect family.

This is the paper’s construct-validity result, and it bounds the whole approach: the phenomenon named in the title is larger than the subfamily the tool (and every handler-shaped detector) operationalises. We state this as a boundary *and* a roadmap — dataflow-shaped failure-routing is future work — and we scope all claims in this paper to the except-handler subfamily accordingly.

Side observation. In the pre-fix `UKGovernmentBEIS/inspect_ai #5068` file the detector flagged a *different, unfixed silent-fallback* at line 356. Real code contains same-family defects that no one has reported.

Detection recall on merged fixes that belong to the failure-routing family

repo	PR	fix title (truncated)	detected	rule matched	note
uqlm	#462	fix(longform): surface NLI retry exhaust	NO	—	miss reason: pre-fix defect is NaN produced by exhausted retries reachi...
inspect_ai	#5068	fix(view): raise a friendly error on A	NO	—	miss reason: handler converts failure via post-handler state mutation (...)
uqlm	#459	fix(panel): keep one failed judge from	NO	—	miss reason: failed judge's NaN entered panel aggregates via data flow,...
PyRIT	#2466	FIX: reject selected attack techniques	NO	—	miss reason: unresolvable techniques were dropped by silent list filter...
PyRIT	#2460	FIX: surface auth config fetch failure	N/A	—	TypeScript (web UI); failroute is Python-only -> out of language scope
uqlm	#450	fix(generation): preserve prompt-respo	YES	no-action	matched: uqlm/utlis/response_generator.py:252(no-action)
inspect_ai	#4906	Report the sandbox's error when remote	NO	—	miss reason: failure masking lives inside tenacity retry semantics (opa...
inspect_evals	#2167	fix(swe_lancer): exclude samples with	NO	—	miss reason: broken invariant was converted to Score(value=0.0) by an o...
unstructured	#4438	fix: fallback character-set detection	NO	—	diff-read J1 FLIP: pre-fix decoded file-like objects with errors="ignor...
PyRIT	#2309	FIX: preserve unknown characters in Br	NO	—	diff-read J1 FLIP: unmapped braille symbols were silently dropped, corr...
trulens	#2653	fix(feedback): validate structured-JSO	YES	no-action	diff-read J1 FLIP: pre-fix silently normalized out-of-scale JSON scores...
uqlm	#425	fix(nli): guard against ZeroDivisionEr	NO	—	miss reason: pre-fix code crashed (ZeroDivisionError propagated); the f...
uqlm	#418	fix(white_box): return NaN instead of	N/A	—	pure-additive fix: pre-fix defect is a non-handler implicit-None (funct...
agent-sweep	#195	fix(scan): stop claiming findings were	NO	—	H-batch (family yes, diff-read): _write_text swallows OSError and calle...
agent-sweep	#197	fix(scan): report unparseable lines an	YES	silent-failback	H-batch (family yes, diff-read): unparseable lines / unreadable files s...
inspect_ai	#4908	Treat malformed multi-letter GRADE ver	NO	—	H-batch (family yes, diff-read): malformed multi-letter GRADE verdicts ...

Recall 3/16 = 18.8% (Wilson 95%: 6.6-43.0%) against all 16 family fixes; 3/14 = 21.4% (Wilson 95%: 7.6-47.6%) against the 14 in-scope subset (out-of-scope rows carry detected=n/a). Denominators recounted from paper/merged-pr-recall.csv by tools/compute_intervals.py.

Figure 3: Recall by defect family against the merged-fix ground truth.

4.5 RQ3b — A tri-source triangulation

The precision result invites the obvious rebuttal: *if 85% of findings are not defects, the detector is noise*. The equally obvious defence — *the defects are real, maintainers just have not noticed them* — is exactly what a false-positive-heavy tool would say, and on spontaneous behaviour alone it is unfalsifiable. We triangulate three truth sources that ask *orthogonal questions* — of, as it turns out, *non-commensurable populations*, which is what bounds the conclusion below. Table 9 sets out the three, with the ground truth each one rests on.

Table 9: The three truth sources and the ground truth each rests on; the datasets behind arms 2 and 3 are described in the text below the table.

Arm	Measures	Value	Wilson 95% CI
1 — consequence labelling (Table 5)	“if triggered, how bad is it?”	12/80 = 15.0% defect, all in one package	8.8–24.4
2 — maintainer spontaneous behaviour	“did anyone notice without prompting?”	13/478 = 2.7% of family sites ever fixed	1.6–4.6
3 — maintainer reaction when told	“when surfaced, do they accept?”	16/43 = 37.2% of our family fix PRs merged	24.4–52.1

Ground truth behind arms 2 and 3. Arm 2’s ground truth is a maintainer-behaviour dataset over the same eight pinned packages, published as `paper/arm2-tracked-sites.csv`. The pipeline behind it tracked 2,128 `try` sites across ten releases of each package and labelled 478 of them FIXED/SURVIVED, discarding 1,650 (77.5%) as too young (924), vanished (681) or mutated (45); none of the 13 FIXED sites traces to an author report — the 9 PR-attributed fixes match no author PR, and the 4 unattributed ones were cleared by package and content check. Two properties of that population bound what arm 2 can be compared against. Its tracking criterion (a handler carrying no raise, log or warn signal) is weaker than the six rules of Section 3, so only 185 of the 478 rows (38.7%) carry a `failroute` rule at the release where they were first observed. And its package mix is 59.4% `deepteam`, against 22.5% of the 621 findings. Arm 3’s ground truth is the merged/closed record of family fix PRs authored by the present author: the 16 merged members are itemised in `paper/merged-pr-recall.csv` — 8 of them in packages outside the tracked eight — and the 27 closed-unmerged members are itemised, with per-PR closure reasons, in `paper/h1_arm3_classification.csv` (copied into this artefact set from the

unreleased companion repository so the composition is third-party checkable): 19 self-closed, 1 bot-closed, 3 closed without reaching the merits, 2 substantively accepted, and 2 adverse on the merits. Excluding the 19 self-closures, acceptance is $16/24 = 66.7\%$ (46.7–82.0) at PR level — one closure (`cvs-health/uqlm#427`) shares its defect substance with a counted merge (`#462`) and two more are duplicates of other submissions, so the 43 PRs overcount distinct defects (40 distinct; see Limitation 3).

Verdict: directionally consistent, not established. The phrase “directionally consistent” is used in one operational sense throughout: no arm exhibits what the strong false-positive reading requires — all contracts and maintainer rejection on the merits — and the two arms that quantify maintainer behaviour line up the same way, spontaneous repair near zero and acceptance when told at 37.2%. With that fixed, the natural headline reading is arithmetic: arm 3’s interval lower bound (24.4%) lies above arm 2’s upper bound (4.6%), the intervals are disjoint, and disjointness is read as supporting “nobody noticed” over “false positive”. The arithmetic is right and the reading is not: what the two denominators count is different, and neither count is warranted.

The arms are not commensurable. Arm 2’s denominator is 478 tracked sites; arm 3’s is 43 defect candidates pre-screened by the author, of whose 16 merged members 8 lie in packages outside the tracked eight. A site-level rate and a self-selected-candidate rate answer different questions about different populations. The gap is not only one of selection: the tracked-site criterion is weaker than the detector’s, so 61.3% of arm 2’s rows carry no `failroute` rule at all, while arm 1’s defect share is measured on findings. No interval comparison across the three arms can support a population-level verdict.

The composition axis, resolved. Whether the intervals are disjoint depends on two quantities: n , the number of tracked sites that are genuine defects, and $k \leq 13$, the number of the 13 spontaneous fixes that landed on defect sites. $k=13$ is the binding corner, since a smaller k only lowers the arm-2 rate. For n , an earlier version of this paper rebased arm 2 with its own unweighted 15.0% share ($n \approx 72$), obtained $13/72 = 18.1\%$ (10.87–28.48), found that this *overlaps* arm 3, and withdrew the verdict on that basis. That rebasing does not survive scrutiny, for two reasons that point the same way. The 15.0% is an unweighted sample share from a design that allocates deliberately unequally — every stratum is guaranteed one draw and the sampling fraction runs 8.9% to 50% — so it is not an unbiased estimate of the frame’s defect share; weighting by that design gives 20.0% (each rule $\times$ package stratum weighted by its frame size) or 19.9% (weighting by package), so the granularity does not matter, only that the design is respected. And a global share of any kind is the wrong shape for this corpus: Table 7 places all 12 defects in `deepteam`, while the 478 tracked sites are 59.4% `deepteam` against 22.5% of the 621 findings. Applying `deepteam`’s own labelled rate ($12/14 = 85.7\%$) to its 284 tracked sites gives $n \approx 243$; its Wilson lower bound alone gives $n \geq 171$. Table 10 crosses that axis with the risk-set convention. In 10 of the 12 cells the intervals remain disjoint, and disjointness needs only $n \geq 86$, i.e. 18.0% of the 478. **The two cells that overlap are both the unweighted 15.0% share applied to a near-complete risk set.** The composition axis therefore does not leave the verdict undecidable; it decides it in the direction of the reported arithmetic.

Why no verdict follows anyway. Every cell of Table 10 answers a counterfactual — what arm 2’s rate would be *if* the tracked sites had the defect composition of the findings. That transfer is not merely unmeasured, it is unsupported: the two populations are not the same objects, and Limitation 2 says n cannot be measured from spontaneous behaviour at all, which is precisely the family’s defining problem. The second degree of freedom is weaker still. Which tracked sites belong in the risk set is a convention this paper did not state: the 478 are the sites the pipeline could label, and 1,650 of 2,128 (77.5%) were discarded. Widening the risk set only widens the gap (Table 10, third and fourth blocks), but the numerator convention does not follow. Counting every vanished site as maintainer action puts arm 2 at $694/1204 = 57.6\%$ (54.83–60.40), entirely *above* arm 3’s 24.4–52.1 — maintainers repairing more of these sites when nobody asks than when asked. That reading is not credible, and nothing in the data excludes it. The comparison is therefore not delicate but ill-posed, and we report the directional agreement without a verdict.

No commensurable substitute exists. The natural repair — compare only sites that are both tracked and PR-reported — is empty: none of the 16 merged family fixes maps to any of the 478 tracked sites (zero exact file matches; the tracked population and the author-reported population are near-disjoint, a consequence of the recall audit’s 3 of 14 in-scope detections and of the 8 out-of-corpus fixes). The closest available approximation is package-level: in `uqlm`, 0 of 12 tracked family sites were spontaneously fixed through the tracked window (Wilson 95% 0.0–24.2; exact one-sided upper bound 22.1) while 5 of 5 author-reported `uqlm` family fixes were merged (Wilson 95% 56.6–100.0). Same maintainer team —

Table 10: The arm-2/arm-3 comparison across *both* degrees of freedom: the risk-set convention (row blocks — which tracked sites count at all) and the defect-share estimator (rows within a block — how many of them are defects). $k=13$ throughout, the binding corner. Arm 3 is fixed at 16/43 (24.38–52.14) and “disjoint” means the arm-2 upper bound lies below 24.38, which requires $n \geq 86$. Intervals are printed to two decimals because the boundary is not a rounding artefact: at $n=86$ the arm-2 upper bound is 24.1636 and at $n=85$ it is 24.4282. The most conservative composition cell — **deepteam** at its Wilson lower bound 60.1% and every other package taken as zero — is $n=171$ (4.50–12.57), still disjoint. Weighting by package rather than by stratum moves the second estimator from 20.0% to 19.9% ($n=95$, 8.17–22.02), also disjoint: the granularity of the weighting does not matter, only that the design is respected. Ten of the twelve cells are disjoint; the two that are not are both the unweighted 15.0% share on a near-complete risk set. Arm 2 as reported (13/478, 1.60–4.60) is not a row here: it treats every tracked site as an opportunity to fix a defect, which no estimator in the table supports.

Risk set	Defect-share estimator	n	k/n	Wilson 95% CI	Disjoint?
478 (as reported)	unweighted 12/80 = 15.0%	72	18.1%	10.87–28.48	no
	design-weighted by stratum = 20.0%	96	13.5%	8.09–21.80	yes
	package composition, $284 \times 12/14$	243	5.3%	3.15–8.94	yes
523 (+ mutated)	unweighted 15.0%	78	16.7%	10.01–26.46	no
	design-weighted 20.0%	105	12.4%	7.38–20.04	yes
	package composition, $284 \times 12/14$	243	5.3%	3.15–8.94	yes
1,204 (+ vanished)	unweighted 15.0%	181	7.2%	4.25–11.90	yes
	design-weighted 20.0%	241	5.4%	3.18–9.01	yes
	package composition, $470 \times 12/14$	403	3.2%	1.89–5.44	yes
2,128 (all tracked)	unweighted 15.0%	319	4.1%	2.40–6.85	yes
	design-weighted 20.0%	426	3.1%	1.79–5.15	yes
	package composition, $621 \times 12/14$	532	2.4%	1.43–4.14	yes

but different site sets, author-selected, and n too small to exclude almost anything. We report it as context, not as a test.

What survives. Three things, each weaker than a verdict.

(i) Directly, the itemised closure record (`paper/h1_arm3_classification.csv`) shows that maintainer engagement with surfaced family defects was mostly, but not uniformly, favourable. Of the 24 non-self-closed outcomes — 16 merged, 7 maintainer-closed, 1 bot-closed — the 16 merges and two closures accepted the substance: the gap reported in `Giskard-AI/giskard-oss#2614` was fixed upstream, though not by the pull request the ledger names — `#2623`, a third party’s restatement of the same change, was itself closed unmerged, and the change landed as `#2647` (merged 2026-08-03, described in its own body as a formatted follow-up of `#2623`); and `cvs-health/uqlm#427` was closed on process grounds with its substance partially re-landed via merged `#462`. Three never reached the merits: two AI-assistance-policy closures of the same `HypothesisWorks/hypothesis` diff, and one duplicate. And **two were adverse on the merits**. In `cvs-health/uqlm#452` the maintainer questioned the reachability of the failure and the question was never resolved — the closest thing in the record to a dispute of the defect’s existence. `vllm-project/vllm-metal#541` was declined as speculative hardening rather than a documented gap. The direct evidence against the *strong* false-positive reading is therefore real but mixed: favourable in 18 of the 24 outcomes at PR level, adverse on the merits in 2, non-merits or non-maintainer in 4 — and all of it on an author-selected subset.

(ii) Spontaneous repair of tracked family sites is rare (2.7%) whatever their composition — but by Limitation 2 that rarity is equally consistent with “mostly contracts”.

(iii) The datum that would settle “nobody noticed” against “false positive” — maintainer reaction to a *random* sample of findings — does not exist and cannot be retro-constructed. We state the question as open and record that datum as a design requirement for future work.

The five limitations, stated with the result.

1. Arm 1 is LLM-judged (two rounds, same model family, 80/80 agreement = shared bias, not quality).
2. Arm 2’s SURVIVED label is only readable as “nobody acted”, never as “deliberate contract” — for this family the two are indistinguishable, which is precisely why spontaneous behaviour cannot validate the detector.
3. Arm 3’s selection bias is irreducible: acceptance applies only to the self-selected reports, not to the

detector’s findings at large.

4. The arms are not commensurable: arm 2 counts tracked sites, arm 3 counts author-selected defect candidates, and 8 of the 16 merged candidates lie outside the tracked packages. No interval comparison between them yields a population-level verdict (Verdict, above; Table 10).
5. Arm 2’s denominator is a convention rather than a measurement: 478 of the 2,128 sites the pipeline tracked, the other 1,650 discarded as too young, vanished or mutated; and only 38.7% of the 478 carry a `failroute` rule, so arm 1’s finding-level defect share does not transfer to them. Neither the exclusion boundary nor the composition of what it retains is measured (Table 10).

4.6 RQ4 — Labelling as a detector-improvement method

All four false positives in the sample were `implicit-fallback`, and all four had the *same* root cause: `_has_top_level_terminal()` inspected only *direct* statements of the handler body, so a `return/raise` nested inside an exhaustive `if/else` was invisible. Table 11 lists the four real shapes that triggered it.

Table 11: The four shapes that exposed the detector bug.

Package	Function	Shape
deepteam	<code>simulate_baseline_attacks</code>	<code>if ignore_errors: return [...] else: raise</code>
fickling	<code>check_pickle</code>	nested <code>try/except</code> , every path returns
inspect_ai	<code>grok generate</code>	<code>if/elif/else</code> , every branch returns or raises
pydantic_ai	<code>execute_output_function</code>	<code>if wrap: raise ToolRetryError else: raise</code>

We implemented a recursive exhaustiveness analysis (`_always_terminates`) covering `if/else`, `with`, `try/except/finally` and `match`, added six regression tests derived from the four real shapes (each failing before the fix), and re-ran the corpus.

implicit-fallback findings on the 524,229 lines the detector actually reads: 10 → 0. Total findings: 659 → 649 (v0.7.0). The v0.8.0 precision release removed 28 more findings through four audited fixes (tuple-typed handlers, `warnings.warn` recognised as a signal, `StopAsyncIteration` added to the ignore list, conservative optional-dependency probe): **649 → 621**, with every deletion traceable to a labelled category or a mechanical criterion — no labelled DEFECT was removed. The test suite grew over the same period, from 124 to 130 (the six regression tests of this subsection) and then to **158** (twenty-eight more with the v0.8.0 precision release).

Two things follow. First, the rule’s entire real-world yield was false. Second, **a stratified labelling pass is not only an evaluation instrument but the only method we applied that exposed a defect in our own detector.** The unit corpus (68 samples, precision = recall = 1.0) never exposed this bug, because the corpus was written by the same person, with the same blind spot, as the detector.

4.7 RQ5 — Refining the predicate, and what it bought

Provenance, stated first because it bounds everything below. The detector in Sections 3 to 4.6 is `failroute` 0.8.0: released on PyPI, pinned by the tag `v0.8.0`, installable by a reader. The detector in this subsection is a later one whose core predicate was rewritten, and it is now released on the same terms: `failroute` 0.9.1 on PyPI, pinned by the tag `v0.9.1`. Drafts of this paper written before that release described it as existing only in the authors’ working tree; that is no longer the case, and the sentence is corrected here rather than deleted because the artefacts under `bench/` were produced before the release. Re-running the released build over the pinned corpus reproduces Result 1’s 476 findings finding-for-finding against the committed export `bench/rescan-v2/` (re-verified 2026-09-07). What bounds the rest of this subsection is therefore not provenance but design: the refactor was developed against the same corpus and the same 140 labels it is measured on, with no held-out set. We say so at the top rather than in Section 6 because it determines the weight the numbers below can bear.

What changed. v0.8.0’s `silent-fallback` rule asks whether the handler’s body returns or assigns a member of a fixed constant set. That is a proxy for the definition in Section 2, which asks something narrower: whether the failure became a value the caller cannot distinguish from success, *and* whether that conversion is the function’s own contract. The refactor replaces the constant test with three layers. (1) **Value-range membership:** if the enclosing function’s declared return type admits the substituted value, the substitution is distinguishable by declaration and the finding is downgraded —

applied only to the return channel and only to explicitly declared ranges, never to an assignment into object state. **(2) Exception–predicate isomorphism:** whether the handler’s work is structurally the same as a `-> bool` predicate the codebase already declares. **(3) Data-flow consequence:** whether the substituted value escapes the call (returned) or outlives it (assigned to object state), which is what makes a substitution caller-visible. Every finding now also carries a severity (INFO, LOW, MEDIUM, HIGH), an isomorphism class, and a static `covered_by` list naming the lint rules that already flag this handler. That list is a table derived by running the four baselines over generated probes rather than by reading rule names (`tools/lint_mapping_probe.py` $\rightarrow$ `bench/lint-rule-mapping.json`); an earlier version inferred it from the handler’s shape alone and got three of its conditions wrong, which Result 2 below reports and corrects.

Result 1: fewer findings, and more of them already linted. Findings fall from 621 to **476** (617 to 472 distinct handler sites; four sites are reported twice in *each* frame, because the assign channel emits one finding per assigned target while the finding identifier is derived from the handler alone — an identifier collision in the refactored detector, noted rather than hidden). The four-linter union’s coverage of those findings **rises** from $255/621 = 41.1\%$ to $252/476 = \mathbf{52.9\%}$ (Wilson 48.5–57.4), and `failroute`-only falls from 366 (58.9%) to **224** (47.1%, 42.6–51.5).

The refactor is not a pruning of the old frame, and treating it as one would overstate its coherence. Over distinct sites, **184 disappeared, 39 appeared and 433 persisted**. Of the 184 dropped sites, 155 (84.2%) had been `failroute`-only; of the 39 added, 15 (38.5%) were. The losses concentrate in `silent-fallback` (177 of 184, plus 4 `no-action` and 3 `silent-suppress`); the additions are all `silent-fallback`. `silent-suppress` falls from 19 findings to 16, so RQ1’s “0 of the 19” is a property of v0.8.0 and does not carry over to this frame. In short the intervention removed linter-invisible findings preferentially and added linter-visible ones — the opposite of what sharpening a predicate is supposed to do if the thing being sharpened is novelty.

Result 2: the crosstab, which is the result. RQ1 measures how much of the family the detector reaches that the linters do not. RQ2 measures how defective the detector’s output is. Neither asks whether those are the same findings. Joining all 140 labels to the refactored frame on (package, file, line) — the handler’s coordinates, deliberately *not* including the rule name, because the refactor can reclassify a handler without dropping it and one label in the sample was reclassified from `implicit-fallback` to `silent-fallback` — 104 join and 36 do not; all 36 come from the frozen 80 and are 33 CONTRACT plus 3 FALSE POSITIVE, so **no labelled defect was lost**, and only one of the 36 sits within two lines of a surviving finding — the failures to join are deletions, not line drift.

Table 12: Defect rate by whether a linter reaches the finding, over the 104 labels that join to the refactored frame. “Co-location” is the empirical criterion of RQ1: some linter actually reported within ± 1 line. “Static `covered_by`” is the detector’s own inference about which lint rules already flag the handler’s shape. That inference was wrong when an earlier version of this paper reported this table; it has since been measured against the real tools and corrected, after which the two criteria agree on every one of the 104 labels and the two blocks are identical. Intervals are Wilson 95% from `tools/compute_intervals.py -rq5`. The two rows within each block do not overlap.

Novelty criterion	Finding class	DEFECT	<i>n</i>	rate (Wilson 95%)
co-location	a linter reaches it	12	48	25.0% (14.9–38.8)
co-location	no linter reaches it	1	56	1.8% (0.3–9.4)
static	<code>covered_by</code> non-empty	12	48	25.0% (14.9–38.8)
static	<code>covered_by</code> empty	1	56	1.8% (0.3–9.4)

The two blocks are the same numbers, and that is a result rather than a redundancy. One column comes from running four linters over the corpus and asking what they flagged; the other comes from the detector reasoning about what they would flag. After the correction described next they disagree on none of the 104 labels — not in aggregate, label by label. The findings four off-the-shelf linters already reach carry a defect rate of 25.0%; the findings the paper called novel carry 1.8%, and the intervals are disjoint. The novelty claim and the defect claim were about largely different findings, in the direction that hurts: what the detector alone could see was very nearly what was not worth seeing.

The static covered_by field was unsound. We measured the whole mapping and fixed it. The inference credited `bandit:B110` and `ruff:S110` to every handler with an inert body, without looking at what the handler catches. Both rules are broad-only. In the state an earlier version of this paper described, the faulty inference called 87 of 476 findings (18.3%) novel against co-location’s 224 (47.1%), and 137 findings it called statically covered were flagged by no linter at all. One of them is `garak/analyze/ci_calculator.py:40`, whose handler is a literal `except (ValueError, TypeError): pass`. Running all four baselines on that single file returns *nothing* — `ruff` reports “All checks passed!”, `bandit` and `flake8` return no rows, `pylint` scores the file 10.00/10. This is a defect in our own instrument, it errs in the direction that flatters the instrument, and we report it as a finding of the study rather than quietly repairing it.

We did not patch the witness; we measured the mapping. `tools/lint_mapping_probe.py` generates 68 probes — eleven caught-type forms (bare; `Exception`; `BaseException`; `builtins.Exception`; a tuple of two narrow names; a tuple mixing `Exception` with a narrow name, with a dotted name, and with a name no resolver can read; a single narrow name; a dotted narrow name; and a caught type that is a call expression) crossed with six body forms (`pass`, `...`, `continue`, a returned constant, an assigned constant, a discarded comparison), plus both `contextlib.suppress` forms — runs all four baselines over them, attributes every hit to the case whose function span contains it, and writes the matrix to `bench/lint-rule-mapping.json`. Every rule carries a positive control, so a selector that silently matches nothing fails the run instead of being recorded as “never fires”. That guard paid for itself twice. `ruff` rejects an unknown selector with exit code 2 rather than an empty result set. And `pylint` accepts W0703 — the retired id RQ1’s baseline enables — and reports those messages as W0718: enabling only W0703 emits W0718 and nothing else, and over the corpus RQ1’s exact selection emits 423 W0718, 134 W0702 and 6 W0706, which is the 563 of Table 3. A reproducer who counts W0703 messages finds zero and would reasonably conclude the broad-except rule never ran.

The measurement found *three* wrong conditions, not the one we started from:

- **Caught type, ruff.** S110 and S112 fire when the handler is bare or catches `Exception`/`BaseException`, including inside a tuple of any composition.
- **Caught type, bandit.** B110 and B112 are narrower still: bare, or *exactly* `except Exception:`. They do not fire on `except BaseException:`, on `except builtins.Exception:`, or on any tuple. Gating all four rules on one “broad” predicate — the obvious fix — would have moved the over-credit rather than removed it, and left `pydantic_ai/_agent_graph.py:205`, an `except BaseException: pass`, wrongly credited.
- **Body form.** S110 and B110 are literally “try-except-pass”: they fire on a body of `pass` and not on a body of `...`, even for a bare handler. This detector’s own notion of an inert body accepts both forms, so the distinction had to be made in the mapping rather than inherited from that flag. On this corpus that third condition changes no number — all 146 over-credited findings have a `pass` body — but it is a real defect and the probe pins it.

Correcting the caught-type conditions then exposed an error in the *opposite* direction, which is the argument for measuring rather than patching. The predicate deciding whether a handler catches `Exception` gave up entirely when any member of a caught tuple was not statically resolvable, so `except (anyio.get_cancelled_exc_class(), Exception):` — three instances in `inspect_ai` — was classified as narrow and kept only its body-form credit (`bandit:B110`, `ruff:S110`), losing the two caught-type credits that do fire on it (`pylint:W0718`, `ruff:BLE001`); and `bandit:B110` should not have been there either, since B110 fires on no tuple at all. That error over-states novelty. Leaving it in place would have made the corrected figure look better for the tool than the truth.

The correction is held by 36 tests, and a suite that passes proves nothing about itself, so `tools/refix_replay.py` rebuilds the pre-correction predicate in a scratch tree and runs the same 36 against it: **21 fail**. Red before the change and green after it, on identical tests — the suite constrains the mapping rather than accompanying it.

Before and after. The correction removes credit from **146** findings and adds it to 3. Of the 146, **137** become statically novel and 9 stay covered because a rule that genuinely fires on them is still credited. All 146 are no-action findings — 93 at INFO, 48 at MEDIUM and **5 at HIGH**. Statically novel findings go from 87 (18.3%) to **224 (47.1%)**, and HIGH findings with no lint coverage from 20 to **25**. What the detector *reports* does not change at all — 476 findings before and after — and neither do the empirical co-location figures (252 covered, 224 novel), because those come from running the linters rather than from inferring anything about them. That the statically novel count and the empirically novel one are now the same number is not a coincidence; see the next paragraph. `tools/rq5_refactor_delta.py` recomputes the whole comparison from the preserved pre-fix export; `tools/lint_mapping_probe.py`

`-check-parity` re-derives the mapping and fails if the shipped inference drifts from it; and 36 tests pin the same conditions, including the reverse direction (a narrow handler must lose the credit, and widening it to bare must restore it).

A residual we had not eliminated — and then did. Five findings of the 476 disagreed with the empirical measure. All five are `except Exception:` handlers that return or assign a constant; the corrected inference credits `pylint:W0718` and `ruff:BLE001`, `BLE001` does fire at exactly that line, and yet the co-location run recorded no linter there at all. Three explanations were tested and ruled out: it is not a parse failure (`pylint` rates `model/_providers/openai.py` 9.96/10 with no fatal or syntax message, and the file’s single `except Exception` is the one it declines to flag); it is not an inline pragma (none of the four files contains the string “`pylint`”); and it is not the `as` binding, which real code uses and the probe originally did not — tested directly, `W0718` fires on `except Exception:`, on `except Exception as e:` and on the same handler that uses `e`, and does not fire on a bare `except:`. The synthetic case that matches these five *does* earn `W0718` in the probe, so the discriminating condition was something about their context. It was our harness, not the linter: all four files sit under a directory with no `__init__.py`, and the directory invocation of `pylint` that Section 4.2 describes and retracts never analysed them. Handed the files directly, `pylint` emits `W0718` at the disputed line in every one of the five. Two corrections follow, and the second reverses a direction this paper previously stated. First, the residual is empty: with the harness fixed, the detector’s static `covered_by` and the empirical co-location agree on **all 476 findings**, not merely on the 104 joined labels — 224 statically novel and 224 empirically novel, and they are the same 224. Second, the earlier claim that the residual “over-credits the linters and understates our novelty” was backwards. `W0718` is inside RQ1’s own `pylint` selection and it does fire on all five, so the empirical measure was *under*-crediting the linters and the reported `failroute`-only count was *over*-stating our novelty by five findings in 476: 229 as previously reported, 224 as measured now. None of the five was a labelled finding, which is why the crosstab in Table 12 never moved — it read 12 of 48 against 1 of 56 before the correction and reads exactly the same after it.

Two consequences for the argument. First, the corrected inference and the empirical one now agree on every finding in the frame, which is why the two blocks of Table 12 are identical and why no residual is left to bound. Second, and it is why the `covered_by` fix was worth making rather than merely documenting: the five additional uncovered HIGH findings it produced are two `except SyntaxError:` `pass`, one `except FileNotFoundError:` `pass`, one `except (OSError, _7Z_ARCHIVE_ERROR):` `pass` and one `except anyio.get_cancelled_exc_class():` `pass` — all narrow-typed, and none in `deepteam`. In the labelled sample narrow-typed handlers carry 0 defects in 46 frozen draws (one-sided upper bound 6.3%, Section 4.3) and 1 in 23 supplementary draws, and that one is the single defect already sitting in the novel cell, which we decline to generalise from below. So the correction multiplies the nominally novel set by 2.6 and the part of it that commands attention by five, without adding any defect evidence. The central comparison survives it unchanged: 12 of 48 against 1 of 56.

Result 3: the layer built for this did nothing. Of the 476 findings the isomorphism layer classified **none** as isomorphic: 254 non-isomorphic, 206 unknown, and 16 with no class at all (the `silent-suppress` findings, which have no handler). A layer that never produces a positive classification contributed nothing to the separation measured above; whatever the refactor achieved came from layer 1 (declared value ranges) and layer 3 (escape channel). Severities across the frame: 208 HIGH, 126 MEDIUM, 129 INFO, 13 LOW.

Result 4: what the refactor did accomplish. All 13 labelled defects survive it, and all 13 sit at HIGH — no defect was lost or downgraded. Of the 122 CONTRACT labels, 33 were dropped and 25 reduced to INFO or LOW: 58 of 122, 47.5%. Restricting to the case layer 1 was built for, contracts whose enclosing function *declares* a `None`-admitting return type, 35 of 38 (92.1%) were dropped or reduced; for a literal `-> None`, 22 of 23 (95.7%). Not all of them, and the exceptions are the interesting part: three declared-contract findings still report at HIGH or MEDIUM, and **two** labelled FALSE POSITIVES survive at HIGH. One is `pydantic_ai/ui/_event_stream.py:293`, an async generator whose handler propagates the error elaborately and which the refactor reports *twice*. The other is `fickling/polyglot.py:150`, which the frozen sample labelled as an `implicit-fallback` over-call and the refactor now reports as `silent-fallback` instead, still at HIGH. The second one is visible only because the join in Result 2 keys on the handler’s coordinates and not on the rule name: a rule-inclusive

join counts a reclassified handler as a deletion and quietly reports one surviving false positive instead of two. And 55 of the 122 CONTRACT labels sit in functions with no declared return annotation at all, so layer 1 cannot apply to them by construction. That is the ceiling on how much noise this design can remove: without type information, the declared-contract test has nothing to read.

The 60 supplementary labels. RQ2’s 80 labels were drawn from the v0.7.0 frame; 72 survive into v0.8.0 and fewer into this one, which is too small a base for a crosstab. We labelled 60 further findings, written to `paper/annotations-v2-additions.csv` — a new file. The frozen `annotations.csv` and `annotations-second-pass.csv` are unchanged and remain SHA-locked; nothing in RQ2 was re-labelled to suit this section. Method: candidates were drawn from the refactored frame with priority on sites whose status the refactor changed and on sites no linter reaches; each was labelled by reading the pinned corpus source, and the detector’s own severity, isomorphism and `covered_by` values were recorded into the row *after* the rationale was written, so the rationale is not a restatement of the verdict; every row carries its rationale, the enclosing signature, and a flag for whether the site is new in this frame. One row is marked in its own rationale as the weakest of the 60 — a borderline CONTRACT that a second annotator could reasonably call DEFECT — rather than being quietly resolved. The outcome was 1 DEFECT, 58 CONTRACT, 1 FALSE POSITIVE. Labels were written by an LLM agent, the same process as RQ2’s, and inherit every limitation RQ2 states about it, including that agreement between runs of one model family is shared bias rather than reliability; we did not run the 60 twice. The 60 are *not* a random sample, so the 140-label figures support a within-sample comparison — covered against uncovered — and no wider inference.

The one defect in the novel remainder. The single DEFECT among the 56 findings no linter reaches is `garak/probes/dan.py:134`, a narrow-typed handler labelled in the supplementary round. We record it because the cell is 1 and not 0, and we do not present it as the detector’s increment. It is one case: one label, from the same LLM process as every other label here, in a package contributing 23 of the 140 rows (16.4%, the second-largest of the eight, and 20 of those 23 from the supplementary round, which was drawn with priority on sites no linter reaches), found after the predicate had already been written. A single observation is not a measured advantage, and it is not the increment RQ1’s 58.9% implied. What it does establish is narrower and more useful: the novel remainder is not empty of defects, so the honest claim is that it is *sparsely* populated with them (1.8%, upper bound 9.4%), not that it contains none.

Reproducing this subsection.

```
.venv/bin/python tools/rescan_corpus.py --out bench/rescan-v2 --with-context
.venv/bin/python tools/coverage_union.py --findings-dir bench/rescan-v2 \
  --out bench/corpus-coverage-union-v2.json \
  --emit-per-finding bench/corpus-coverage-per-finding-v2.jsonl
.venv/bin/python tools/coverage_union.py --findings-dir bench/rescan-f2 \
  --out bench/corpus-coverage-union-621frame.json \
  --emit-per-finding bench/corpus-coverage-per-finding-621.jsonl
.venv/bin/python tools/e722_baseline.py          # -> bench/e722-baseline.json
.venv/bin/python tools/rq5_refactor_delta.py    # -> bench/rq5-refactor-delta.json
.venv/bin/python tools/compute_intervals.py --rq5 # -> bench/intervals-v2.json
PYTHONPATH=src .venv/bin/python tools/lint_mapping_probe.py --check-parity
# -> bench/lint-rule-mapping.json; re-runs all four baselines over 68
# generated probes and exits non-zero if the shipped covered_by table
# drifts from what those baselines actually do
.venv/bin/python tools/pinned_rescan.py --out /tmp/pinned-v080
# -> re-scans the pinned corpus with the v0.8.0 detector, from a git
# worktree at that tag, using that tree’s own src and exporter; prints
# PINNED_TOTAL=621 plus the per-rule and per-package counts. This is what
# the claims asserting v0.8.0’s historical scan results now run through.
PYTHONPATH=src .venv/bin/python tools/refix_replay.py
# -> rebuilds the pre-correction covered_by_for in a scratch tree and runs
# the 36 mapping tests against it; prints REFIX_REPLAY 21 failed, 15
# passed. The fail-to-pass half of the correction’s evidence.
```

The third command is the one that makes RQ1 reproducible from the repository rather than from a scratch directory: `bench/rescan-f2` is the same 621 findings committed in-tree, and re-running the union over it reproduces 621 / 255 / 366 and every per-rule and per-tool cell of Tables 3 and 4 exactly. `bench/corpus-coverage-union.json`, the artefact every RQ1 figure is read from, is now generated from that directory and no longer records a scratch path no clone contains. The `-rq5` interval mode writes `bench/intervals-v2.json` and deliberately leaves `paper/intervals.json` byte-identical, so the frozen artefact RQ1–RQ4 are computed from is not disturbed by this section.

4.8 Control-corpus comparison

Design. The main corpus is dominated by one handler shape: 134 bare `except:` clauses, 131 of them in a single package, holding all 12 confirmed defects. Any claim of the form “the lint baseline already covers the defects” may therefore be an artefact of code style rather than a general fact. The control corpus inverts the style: across its eight package bodies (263 `.py` files, 109,400 lines, 842 handlers) there is exactly one bare `except`, in `msgpack/fallback.py:812`, whose handler resets the buffer and re-raises — so even the single E722 candidate is a non-defect. The detector build is the frozen 0.9.x predicate, unmodified; the four baselines run with RQ1’s exact rule selection and ± 1 -line matching. The four first packages contribute 243 handlers and 0 bare clauses; the four added for domain diversity contribute 599 handlers and the 1 re-raising bare clause.

Result: density does not collapse, E722 does. Table 13 contrasts the two styles. Finding density is 21.0% (476/2,270) against 15.6% (38/243) on the first four control packages and 18.3% (154/842) on all eight: no order-of-magnitude gap, so “the tool reports less on disciplined code” is not the story. The story is the trivial baseline. `flake8 -select E722` returns 134 candidates on the main corpus, containing all 12 confirmed defects; on the control corpus it returns 1 candidate, containing none, for a recall of zero. A two-proportion z test of Group A against the four-package control core (476/2,270 vs 38/243) gives $z = 1.96$, $p = 0.050$, on the significance boundary; against all eight control packages (154/842) it gives $z = 1.65$, $p = 0.098$, and is not. We name the pair because the choice decides which reading applies, and we therefore state neither “constant” nor “different”: no comparison here is statistically significant, and the sample is too small to assert equality.

Result: the 38 control findings contain no defect. All 38 findings on the first four packages were adjudicated handler by handler (file, enclosing function, all read sites; the two HIGH findings additionally against repository history, closed-issue records and pinning unit tests). Zero are defects, which bounds the defect share at 7.6% one-sided 95% Clopper–Pearson — against 77.6% had only the 2 unique-HIGH findings been read. The 2 unique HIGH findings are both documented contracts. `attrs/src/attr/_compat.py:51` catches (`ValueError`, `TypeError`) when `inspect.signature` fails and stores `None`; the class docstring states it returns `None` “whenever there is none”, both read sites guard on the field, the shape dates to 2022 (#912), and a unit test pins the extractor’s behaviour. No closed issue reports it swallowing a failure. `urllib3/src/urllib3/connectionpool.py:812` catches transport errors, wraps each into a `ProtocolError`, feeds it to `retries.increment` — which raises `MaxRetryError...from reason` on exhaustion (`util/retry.py:543`) — saves it for the retry warning, closes the connection in `finally`, and recurses into `urlopen`; the exception is never swallowed. That control-flow structure dates to 2009 with a 2016 revision, and the retry-exhaustion tests assert the `MaxRetryError` propagation. The remaining 36 findings are the same contract shapes as the main corpus’s benign tail: optional-dependency and codec probes, `try/except/else` sentinels, re-raises, and teardown handlers.

Result: the recall side is exhaustively clean. Of the control corpus’s 243 handlers the tool reports 38; 114 unreported handlers contain a `raise` and need no review; the remaining 91 silent-and-unreported handlers were each read. Zero are misses the tool should have caught — optional-import and capability probes, `StopIteration` protocol handling, `dict.get` and `list.index` sentinels, documented best-effort fallbacks (`requote_uri`, `get_unicode_from_response`), data-model protocol returns (`NotImplemented`), and CLI exit paths. Exhaustion means exhaustion: 91 of 91 with zero misses is a true zero-leak statement, not an interval. The 15 prior pilot draws this replaces had a residual bound of 18.1%.

The four diversity packages agree. `click` (31 findings, 13 HIGH), `anyio` (45 findings, 1 HIGH), `pydantic` (40 findings, 1 HIGH) and `msgpack` (0 findings) reproduce the pattern: 12 of the 15 HIGH findings are **except** Exception capability probes already covered by BLE001/W0718 (Windows-console shims, stream predicates, `TaskGroup` propagation with explicit re-raise paths). The 3 uncovered HIGH findings are contracts on reading: `click/core.py:161` is a `list.index` probe returning infinity as the documented sort key; `click/types.py:269` converts the user’s `ValueError` via `self.fail`, which raises `UsageError` — the exception escapes through a call rather than a `raise` statement, a shape no callee-local rule can see; `pydantic/v1/_hypothesis_plugin.py:125` is a `contextlib.suppress(Exception)` digit search in hypothesis test-support code, confirming the SIM105-adjacent blind spot of Section 4.2 from the other side.

A fourth intra-procedural undecidability instance. `connectionpool.py:812` names a new false-positive mechanism: **state-flag amplification**. The finding is `clean_exit = False` (set alongside `release_this_conn = False`), a control-flow flag consumed in `finally` and after the handler; the **amplifies** criterion (“the value outlives the call”) promotes it to HIGH exactly as it would a substituted return value. Telling the two apart requires knowing where the variable is consumed, which lies outside the handler. Like the three constructed counterexamples and the **exception_escapes** case below, it is documented here and left in the code: each is an instance of the limit the paper argues, and patching them would weaken the evidence they constitute.

Table 13: Style-opposite corpora, same detector build and baseline selection. Densities are findings per handler inside the scan roots. E722 recall is measured against adjudicated defects (12 in Group A, 0 found in Group B).

	Group A	B core (4 pkgs)	B all (8 pkgs)
Handlers	2,270	243	842
Bare except :	134	0	1 (re-raise)
Findings	476 (21.0%)	38 (15.6%)	154 (18.3%)
HIGH	208	6	21
Unique HIGH (<code>covered_by</code> empty)	25	2	5
E722 candidates	134	0	1
E722 recall of defects	12/12	0/0	0/0
Adjudicated defects	12/80 + 1/60	0 of 38	0 of 38, 0 of 15 new HIGH

Reproducing this subsection.

```
PYTHONPATH=src .venv/bin/python tools/control_rescan.py --check
# -> verifies bench/control-rescan/<pkg>.jsonl against a fresh fetch
# (SHA-256 checked per paper/corpus-lock-control.json) and re-scan;
# prints CHECK-OK per package, exits non-zero on any drift.
.venv/bin/python tools/compute_intervals.py --control
# -> prints the 7.6% bound, z=1.96, p=0.050 from the committed jsonl.
```

5 Discussion

A detector this imprecise is still useful, but not as an oracle. On our corpus a maintainer following up every finding would read 621 handlers to reach ~120 genuine defects (84–134), essentially all of them three copy-paste families in a single package. That 120 is a cross-frame extrapolation rather than a measurement, and a deliberately package-aware one: it applies `deepteam`’s labelled rate (12/14) to its 140 findings and counts the other seven packages as zero, because Table 7 gives no warrant for spreading a global share across them. It also inherits the clustering problem of Section 4.3 in full: `deepteam`’s 12/14 is twelve observations that are *three* code patterns, so the ~120 is a projected count of copies rather than of distinct bugs, and 84–134 is an interval on that copy count. We leave the figure standing rather than deflating it by a factor we cannot derive — the copies would still be found and still have to be read, which is the cost claim being made here — but the replication factor on the labelled sample is four (twelve observations, three patterns), and any reader who takes ~120 as a yield of distinct defects should divide by something of that order. The ~93 that a global 15.0% would imply

is exactly the homogeneous extrapolation that the per-package breakdown rules out. The 15.0% share is itself measured on the v0.7.0 sample frame while the 621 count is v0.8.0, and Section 6 carries the caveat. As an *alarm*, that is unusable. As a *search-space reducer* it is a different proposition — but the honest comparison is then not against the corpus, it is against a cheaper reducer. The eight pinned sdist contains 563,270 lines, of which 524,229 sit inside the scan roots the detector actually reads and produces the 621 from. Against those 524,229 lines the detector’s reduction is a factor of 844 (2.93 orders of magnitude); the 907 that 563,270 would give pairs the findings with lines the detector never read. `flake8 -select E722` reduces the *same* 524,229 lines to 134 candidates — a factor of 3,912, or 3.59 orders — and contains all 12 confirmed defects. Measured against that, the detector’s list is **4.63× longer at equal recall** on the labelled defects, and the single labelled defect the E722 list misses is one narrow-typed case that Section 4.7 declines to claim as an increment. So the reduction the tool contributes is real against a maintainer reading the corpus and negative against a maintainer running one linter flag. And a reading of 80 sampled handlers found a systematic fail-open security verdict in a red-teaming tool — which is the actual argument that this family is worth a look, and it does not require this detector to be the thing that looks.

The triangulation reframes the negative precision result — as a non-identifiability result. 15% defects — 4.4% once the three replicated families are counted as the three patterns they are — is bad for an alarm and unremarkable for a search tool; the interesting fact is that the family’s defining property — silence — also disables the usual external check on the number. Spontaneous repair of tracked family sites was 2.7%; when the author surfaced adjudicated defect candidates, acceptance was 37.2%. These numbers measure different populations and cannot be combined into a verdict (Section 4.5) — but not for the reason an earlier version of this paper gave. The interval comparison is not fragile: 10 of the 12 defensible rebasings of arm 2 leave the intervals disjoint, and the two that do not are both the unweighted 15.0% share, which the sampling design and the package breakdown alike discredit. The comparison fails for a plainer reason. Its three arms count three different kinds of object — labelled findings, tracked sites of which only 38.7% carry a `failroute` rule at all, and author-selected pull requests — so there is no population whose rate all three estimate. That is a limit of the data and not a theorem about the family, which is why we call it *non-identifiability* rather than impossibility: the paper can name the observation that would identify it. What the triangulation establishes is narrower: for this family neither spontaneous behaviour nor triangulation around it can validate a detector; the reason is quantifiable (a two-dimensional sensitivity, Table 10); and the missing datum is nameable — maintainer reaction to a random sample of findings.

Yield tracks codebase maturity, not rule design. The strongest predictor of whether a finding is a defect was not *which* rule fired but *which package* it fired in. The mature, heavily-reviewed packages had essentially no defects and a large number of carefully-commented intentional contracts; the one package with a systematic problem had it replicated across dozens of near-identical files. This suggests triage effort should be allocated per-package after a cheap pilot sample, not uniformly.

Four layers of overfitting, stated against ourselves. The refactor’s gains should be read as an overfitting report, not a quality certificate. First, the acceptance gates demand no-regression on the same corpus the patches were developed against, so every patch is fitted to its own test set by construction. Second, all 140 labels (80 + 60) were available during development; there is no held-out set, and the 60 supplementary labels were drawn precisely from sites whose status the refactor changed. Third, every counterexample that moved the argument — the three constructed probes below, the state-flag mechanism of Section 4.8, the mapping defects of Section 4.7 — arrived from outside review; self-inspection caught none of them. Fourth, and it is the terminal one: callee-local analysis cannot define “the caller cannot distinguish” without caller intent, so its separation criterion is necessarily a syntactic proxy, and proxies fitted on one style fail on the next. The control corpus is the check we should have built first: it finds no defect the tool can uniquely claim, on either style.

The conclusion the evidence supports. Failure-routing is an *inter-procedural contract mismatch*: whether a caught exception substituted by a value is a defect depends on what the caller is entitled to assume, and that assumption lives outside the handler. Any heuristic confined to the callee therefore degrades, without caller intent, into fitting the shapes of whatever corpus it was tuned on. The call-site evidence for a cross-procedural rescue is too thin to change that verdict: a textual same-package call

search over the 267 distinct flagged functions finds at least one candidate call site for 153 (57%), median 1; even counting every bare textual mention, including comments and string literals, reaches only 208/267 (78%) with median 2. The reachable sites exist, but at one or two mentions each they carry no usable statement of intent — the problem is semantic density, not reachability. `tools/compute_intervals.py` -control recomputes the control cells. The call-site counts are the one exception to this paper’s reproduction rule: they came from ad-hoc scripts that were not kept, so unlike every other number here they cannot be re-derived from the repository. We state them as audit figures rather than claims, and no conclusion rests on them.

Three constructed probes that pin the boundary — code frozen. External review supplied three minimal probes, verified against the frozen 0.9.1 build on 2026-09-06: `is_admin() -> bool` with `except DatabaseTimeout: return False` is missed (a specific-typed handler in a boolean probe is excused even when the caught exception is operational); `fetch_cached_token() -> Optional[T]` with `except RedisConnectionError: return None` is missed (a declared `Optional` excuses hiding an infrastructure failure as a legitimate absence); and a validation loop with the `try outside the for` and `except ValueError: return False` is reported at HIGH (a short-circuit validation idiom flagged as failure-routing). All three live in **Threats**: they are the sharpest statement of the intra-procedural limit, and fixing them would trade evidence for comfort. The same holds for the `exception_escapes` case (`realtime/_session.py:2156`, where the exception object travels inside the returned value) and the state-flag amplification of Section 4.8: four known imprecisions, documented in the changelog of the frozen 0.9.1 rather than patched.

The `contextlib.suppress` blind spot is real. 0/19 of the findings are visible to the four selected rule sets, and none is reported by `ruff` with all 969 of its rules enabled or by `pylint` with its full default message set either; a popular lint rule actively drives code toward that shape. Only a semgrep rule we wrote reaches them (18/19).

Adoption, honestly. The tool is published on PyPI as `failroute`; at the 2026-09-01 measurement freeze it had **1 star and 0 forks**. We claim no adoption and no impact beyond the measurements in this paper; the maintainer-behaviour dataset and the triangulation method are the contributions we ask the reader to weigh.

On “tool proposes, human adjudicates”. We report a case where we ran the detector over a well-maintained red-teaming framework, sampled twelve semantic findings, traced each, concluded all twelve were deliberate contracts, and *filed nothing*. Given the base rate measured here — 15% unweighted, 20.0% weighted by the sampling design — that outcome is what the numbers predict, not an anomaly.

6 Threats to validity

The first five items are the limitations the triangulation verdict in Section 4.5 depends on, and are cited there by name; the rest are the study’s other threats.

- **Limitation 1 — the labelling arm is LLM-judged.** Both labelling rounds were performed by LLM agents, not human raters; the rounds agreed on 80/80 items, which we read as *shared bias of one model family, not as inter-rater reliability*. No Cohen’s κ is possible between two runs of the same rater species. All arm-1 proportions inherit this limit. The committed artefacts record the labels and the rationales but not the model identity or version, so a third party cannot re-run the labelling bit for bit. We were not able to recover that identity and therefore do not name a model: every “defect rate” in this paper is an LLM-adjudicated rate under an unrecoverable model configuration, and the weighted variants of it inherit exactly that limit.
- **Limitation 2 — SURVIVED is ambiguous in this family.** In the maintainer-behaviour dataset, SURVIVED can only be read as “nobody acted”; it can *not* be read as “maintainers consider it a deliberate contract”, because for silent defects the two are observationally identical. Any number derived from arm 2 inherits this reading restriction.
- **Limitation 3 — arm-3 selection bias is irreducible.** The author chose which defects to report as PRs; acceptance (16/43) applies only to that self-selected set and cannot be extrapolated to the detector’s findings. Reporting only merged PRs would have made this worse; the 27 closed-unmerged family PRs are counted in the denominator and are itemised, with closure reasons, in

`paper/h1_arm3_classification.csv` (copied from the unreleased companion repository so the composition is checkable). Both ledgers are snapshots of the 2026-09-01 freeze rather than live queries: the author has merged further pull requests since, so a reader who re-runs the count today gets a larger denominator and a set of adjudications that does not include them. Three counting caveats: one of the 8 non-self-closures was a *bot* action, not a maintainer judgement; two of the 27 are duplicates of other submissions and one more shares its defect substance with a counted merge, so the 43 PRs overcount distinct defects; and 8 of the 16 merged fixes lie in packages outside the tracked eight — arm 3’s population is not arm 2’s. On the distinct-defect denominator those three rows come out, leaving 40 defects and an acceptance of $16/40 = 40.0\%$ (26.3–55.4). We keep 16/43 as the headline because each of the 43 is a separate maintainer decision, and state 16/40 beside it so that neither reading has to be inferred.

- **Limitation 4 — the triangulation’s arms are not commensurable.** Arm 1 counts labelled findings, arm 2 counts tracked sites, arm 3 counts author-selected defect candidates, and 8 of arm 3’s 16 merged candidates lie outside the tracked packages. No rate is common to the three, so the interval comparison supports no population-level verdict however it is rebased; we report directional consistency only.
- **Limitation 5 — arm 2’s denominator is a convention, and its population is not the detector’s.** The pipeline tracked 2,128 sites and labelled 478 of them, discarding 1,650 (77.5%) as too young (924), vanished (681) or mutated (45); nothing in the data selects among the resulting risk sets (Table 10). Its tracking criterion — a handler carrying no raise, log or warn signal — omits the detector’s three exemption gates and its fallback-value analysis, and never considers `contextlib.suppress` at all, so only 185 of the 478 rows (38.7%) carry a `failroute` rule. Arm 1’s defect share is measured on findings and does not transfer to that population, which is why every cell of Table 10 is a counterfactual rather than an estimate.
- **Sample size.** $n = 80$ of the v0.7.0 frame (659). Per-rule and per-package cells are small (`masked-exception` $n = 1$). Wilson intervals are reported throughout instead of bare point estimates.
- **Sample frame changed under the sample.** The draw came from v0.7.0’s 659; 72/80 coordinates survive in v0.8.0’s 621, and the deletions removed zero labelled DEFECTs — but the surviving 72 are no longer a random sample of the current frame. Label proportions are stated for the v0.7.0 frame only.
- **Package selection is not random.** The eight packages were chosen because the author had prior contribution history in them. `deepteam` in particular is a package where the author had *already found* a defect family, which inflates the overall defect rate. The seven-package 0/66 figure is the more conservative read.
- **Recall ground truth is authored by the same person.** The 16 merged family fixes were written and submitted by the author; a maintainer merge records that the change was acceptable to the project — it is not a maintainer finding that the pre-fix behaviour was a defect, and it says nothing about representativeness. The family adjudication of all 75 merged PRs was done by reading diffs (52 earlier title-only judgements were re-verified from diffs in a dedicated pass, with 3 corrections).
- **Co-location $\neq$ equivalent detection** (Section 4.2 caveat). Reported conservatively as an upper bound on baseline coverage.
- **The fifth baseline tool is ours.** The `semgrep` rule counted in the five-tool union was written by the author; coverage attributed to it is self-supplied.
- **Construct validity (Section 4.4).** The detector operationalises the `except-handler` subfamily only; 64.3% of ground-truth defects lie outside it. All prevalence/recall claims are scoped to the subfamily.
- **Control scope is two styles, not the ecosystem.** The control comparison covers a zero-bare-`except` infrastructure style against the main AI/ML style; both are Python, both are PyPI. The conclusion carried by Section 4.8 is scoped to those two corpora, this detector build, and this adjudication protocol. A third style, another detector, or another annotator could move it, and the 7.6% bound is over findings, not over the defect prevalence of disciplined code at large.
- **Control adjudication is single-annotator.** The 38 findings and the 91 recall-side handlers were read once, by one annotator, with history, issue-record and test evidence taken only for the 2 unique HIGH findings; the remaining $36 + 91$ rest on in-source contract evidence (`docstrings`, guarded read sites, explicit fallback comments, re-raise paths). Borderline CONTRACT-vs-DEFECT calls were resolved toward CONTRACT wherever a documented policy existed; the direction of that bias is stated so a re-adjudication can test it.
- **Call-site counts are method-sensitive.** The 57% / median-1 and 78% / median-2 figures in

Discussion are two textual search methods over the same 267 functions; an AST name-load count gives 33% with median 0. All three agree the evidence is thin, but none is a call graph, and dynamic dispatch, re-exports and cross-package callers are uncounted throughout.

- **Known imprecisions are frozen, not fixed.** The three constructed probes, the state-flag amplification (Section 4.8) and the `exception_escapes` case (Section 4.7) are documented failure modes of the shipped 0.9.1 predicate, and the dead-comparison family of the next item is a fifth. Any precision figure in this paper is net of the first four.
- **Dead-comparison family: the rule fired on the right site for the wrong reason.** Section 4.3 describes family 2 as a bare `except:` assigning `self.success = False` around a `try` body that holds the single discarded comparison `self.score == 1`. We re-read all five of those sites in the pinned corpus (`metrics/cross_context_retrieval`, `external_system_abuse`, `hijacking`, `rbac`, `shell_injection`) and confirm the three facts the committed rationale records. A discarded comparison has no side effect, and it raised nothing for any value we placed in `self.score` — `None`, `int`, `float`, `str`, `bool`, `tuple`, `list`, `ndarray` — so the handler is unreachable and *no failure is converted at these five sites*. `silent-fallback` fired anyway: it reads the handler’s shape (assigns a constant, does not re-raise) and carries no reachability gate, so it located a genuinely broken function and attributed the wrong mechanism to it. What is broken at the site is a missing assignment — each of the five files states the intended form twice, in `measure` and in `a_measure`, which is why `is_successful`’s `else` branch is a no-op that returns whatever those two left behind. The DEFECT reading survives, because the site is not a documented contract, but it survives on the missing assignment: the “converted failure produces a wrong caller-visible outcome” half of the definition is not demonstrated for these five, and a reader who requires the stated mechanism to hold should treat the mechanism as established for the other seven and as unestablished for these. Unlike the four imprecisions above, this one sits inside the labelled DEFECTs rather than outside them, so no precision figure in this paper is net of it — the five are counted as true positives, and on the reading just described they are true positives about a different defect than the rule names. Two further checks bound the impact without resolving it. `is_successful` has no caller anywhere in the pinned sdist, so no in-package path exercises it; and the value `self.success` holds before either `measure` runs is set by `deepeval`’s `BaseMetric`, which is neither vendored in the corpus nor installed in the reproduction environment, so the never-measured path is unverified rather than benign. The other two families are unaffected: family 1’s handler guards `model.get_system_prompt()` on a parameter typed `Optional`, and family 3’s guards an attribute access and an ordering comparison, `metric_data.score < 1`; both raise `AttributeError` for values those parameters accept, so in those seven the conversion mechanism is the one the label states. We did not re-adjudicate the five: the labels and their rationales are the committed artefact, and this item records the correction instead of acting on it.
- **Version pinning is a snapshot.** All findings are relative to the pinned versions in `paper/corpus-lock.json`; upstream may have fixed or introduced instances since.

7 Related work

Failure handling as an empirical object. Exception handling has a long empirical literature in statically typed languages: Cabral and Marques’ field study of Java and .NET [6] documented how often exceptions are caught and swallowed; Sawadpong et al. [20] characterised exception-handling *defects*; and de Pádua and Shang quantified the prevalence of named exception-handling anti-patterns over a large corpus [4] and revisited developer practice through exception-flow analysis [3]. That line of work asks *whether* anti-patterns occur and *how often*, and it is our closest neighbour: we inherit its premise that handling shape is measurable, and change the question. On a corpus of Python AI/ML packages, the same syntactic shapes that read as anti-patterns are predominantly *intended contracts* — in our stratified sample of 80 sites, 80.0% carried a contract reading and 5.0% were outright false positives, with the defect share concentrated almost entirely in one package. A prevalence number without a per-site defect/contract breakdown does not by itself support a triage decision; supplying that breakdown is what the present measurement adds.

Why generic rules get muted. A second body of work explains the reception of such numbers. Developers report false positives and noise as the leading reason they ignore or abandon static analysis [12]; Ruthruff et al. made *actionability* an experimental target rather than a slogan [16]; Google’s Tricorder and FindBugs-Fixit programmes showed that an analysis only survives at scale when it is filtered, pri-

oritised and paired with a suppression path [2, 17, 18]. User-centred and follow-up studies reach the same ordering from the other side: what developers need is a warning they can act on [9, 22], and the mitigation of false positives remains an open problem rather than a solved one [10]. WarningsGuru operationalised relevance with statistical bug models [15], and Hu et al. recently measured the other end of the same pipe — which warnings developers actually suppress, and on what grounds [11]. Crisan and McNutt frame linting as a sociotechnical activity [7]. Our contribution is not another relevance filter: it is a *semantic* account of why a particular family of syntactic matches is disproportionately non-actionable, so that a suppression decision can be justified by code shape rather than by developer fatigue.

Silent failure in machine-learning systems. The systems literature supplies the stakes. Sculley et al. named the pipeline coupling and glue-code debt that makes ML behaviour brittle [21]; Polyzotis et al. proposed continuous data validation as the corrective at the data boundary [14]; the ML Test Score encoded a rubric that tests the pipeline rather than the model alone [5]; Amershi et al. and Paleyes et al. documented that the failures arrive at integration and deployment time, not training time [1, 13]; Sambasivan et al. traced how a data problem cascades through a high-stakes system until it surfaces as an unexplained outcome [19]; and Dixit reported silent data corruption at scale in production hardware, where no exception is raised at all [8]. Zhang et al. position testing and robustness techniques across that same spectrum [23].

Increment over the two closest studies. Read side by side, de Pádua and Shang [4] and Hu et al. [11] bound the problem on either side: the first measures how often a handling shape appears, the second measures what developers do once a tool points at it. Neither asks, *per site*, whether the flagged construct is a defect, an intended contract, or a tool artefact — and neither reports what a purely syntactic linter fails to see at all. This paper supplies both measurements for Python AI/ML code: a labelled 80-site sample (12 DEFECT / 64 CONTRACT / 4 FALSE POSITIVE, with the defect mass concentrated in one package), and a cross-tool comparison showing that four widely used syntactic linters jointly cover 41.1% of the 621 routed-failure sites we detect, with one entire pattern — `contextlib.suppress`-style silent suppression — at 0/19 to shipped rules. The increment is therefore empirical and narrow: the *meaning* of a flagged handler, and the *coverage boundary* of the tools practitioners actually run.

8 Conclusion

Except-handler failure-routing is a real and prevalent shape in AI/ML Python: 621 instances in the 524k lines the detector actually reads, 58.9% of them outside the reach of four mainstream syntactic linters, and none of the 19 `contextlib.suppress` variants reached by any rule those four ship or by `ruff`’s full 969-rule set. But prevalence is not defectiveness, and the defectiveness we could measure is both smaller and narrower than the prevalence. In an LLM-labelled stratified sample 15% were genuine defects and 80% were deliberate contracts, with the defects concentrated entirely in a single package; weighting that sample by its own design raises the share to 20.0%, and clustering it by the code identity the defects actually have — three replicated patterns — lowers it to **4.4%** (Wilson 1.5–12.2). We quote the clustered figure as the estimate and the 15% as description, because the 12 defects are copies and a Wilson interval on 12/80 treats them as independent. Every one of them sits in a bare `except`; across the 46 narrow-typed handlers in the same sample the defect count is zero, one-sided upper bound 6.3%.

The negative result is the one we did not set out to get. Replacing the detector’s predicate with the criterion its own definition states — not “returned a constant” but “converted the failure into a value the caller cannot distinguish from success, where that conversion is not the function’s contract” — cut the findings from 621 to 476 and *raised* the share four off-the-shelf linters already reach, from 41.1% to 52.9%. Over 140 labels the findings no linter reaches carry 1 defect in 56 (1.8%, 0.3–9.4) while the findings linters do reach carry 12 in 48 (25.0%, 14.9–38.8). The layer built to make that distinction — exception/predicate isomorphism — classified *no* finding as isomorphic, so it contributed nothing to the separation. What the refactor bought is real and narrower than advertised: it kept all 13 labelled defects at HIGH and removed or downgraded 92.1% of the contracts whose function declares a None-admitting return type, but three of those still report at HIGH or MEDIUM, and one labelled false positive survives at HIGH and is reported twice. And `flake8 -select E722` lists 134 candidates over the same corpus

containing all 12 confirmed defects: a reading task $4.63\times$ shorter than the detector’s 621 at equal recall on those labels, and $3.55\times$ shorter than the refactored 476.

The methodological contribution is a quantified non-identifiability result. For a defect family whose defining property is silence, “did maintainers fix it?” is a broken validation instrument — spontaneous repair of tracked family sites was 2.7% — and the natural workaround fails too: triangulating against maintainer reaction when told (37.2% acceptance of author-reported candidates) compares populations that are not merely differently selected but differently constituted, so no rate is common to the three arms. The interval disjointness that appears to support the “nobody noticed” reading is in fact robust — it survives 10 of the 12 defensible rebasings of arm 2 — and is still worth nothing, because the denominators do not count the same objects, and there is no matched-population substitute. What remains is honest but narrower: directionally consistent observations, a closure record in which maintainer adjudication of surfaced family defects was favourable in 18 of 24 outcomes but adverse on the merits in two (an unresolved reachability challenge and a scope decline), and an open question whose missing datum we name — maintainer reaction to a random sample of findings. And the recall audit supplies the honest boundary: 3 of 14 ground-truth defects detected, and 64.3% of them route the failure outside any handler — the phenomenon is larger than the subfamily we, and every handler-shaped detector, can see.

We think the useful conclusion is neither “this class is undetectable” nor “our tool detects it”. It is that the cheap syntactic rule and the expensive semantic detector disagree about *which* handlers matter, and on our labels the cheap one is right more often: the property that separated defects from deliberate contracts in this corpus was whether the handler is bare, and that is a one-flag lint rule. Detectors for this family should therefore be evaluated against the trivial baseline *before* they are evaluated against the corpus — a reduction factor quoted over lines of code measures the corpus, not the tool — and should be deployed as search-space reducers with an explicit human adjudication step only where an increment over that baseline has been measured. On the labels we have, ours has not been: one case, which Section 4.7 declines to generalise from. The labelling pass that establishes this should still be run early. In our case it was the fastest way to find a bug in the detector, and then the fastest way to find that the refinement built to fix the bug’s underlying imprecision did not help.

9 Reproduction and artefacts

Every number in this paper is produced by the scripts in `tools/` against the pinned corpus in `paper/corpus-lock.json`, with one exception that the Discussion flags where it appears: the call-site ratios quoted there came from ad-hoc scripts that were not kept, and are stated as audit figures rather than claims. All paths below are relative to the root of the public repository <https://github.com/feiiiiii5/failroute> (MIT licence); the detector itself is released as `failroute` on PyPI, <https://pypi.org/project/failroute/>. The version studied in RQ1–RQ4 is 0.8.0 (PyPI), and the immutable tag `v0.8.0` pins the detector release. The artefact set the tables are computed from, however — the arm-2 dataset `paper/arm2-tracked-sites.csv`, the `rebase*` cells of `tools/compute_intervals.py`, and the symmetric-baseline variant of `coverage_union.py` — postdates that tag, so the reproduction below checks out a pinned commit instead: `d14e020`, the first commit that contains the complete set. A reproducer who checks out `v0.8.0` still regenerates the 621 findings and the 158 tests, but `compute_intervals.py` at that tag exits 0 while silently writing a 41-cell ledger that contains no triangulation group at all, and the symmetric-baseline command below fails there with an unrecognised-argument error — so the tag alone under-reproduces this paper without warning. `coverage_union.py` at that commit under-reproduces it in a second, subtler way: it still passes each scan root to `pylint` as a directory, which is the blind spot Section 4.2 describes, so it returns the superseded 250/621 union rather than the 255/621 this paper reports. The corrected invocation is in the working tree and the difference is confined to one function; a reproducer who wants the paper’s numbers must run that one. The 250/621 figure is recorded here so that the two readings are not mistaken for a disagreement about the corpus.

Section 4.7’s detector is a second release rather than a gap. It is `failroute` 0.9.1, pinned by the tag `v0.9.1` and published on PyPI. Drafts of this paper written before that release stated that it existed in no tag, no release and no commit; that statement is withdrawn. The artefacts it produced ship with the repository — the per-finding rescan under `bench/rescan-v2/`, the two coverage exports, the frame-difference report and the interval ledger, all listed below — so a reader can re-derive every interval and crosstab cell in this subsection with `tools/compute_intervals.py -rq5` and

`tools/rq5_refactor_delta.py`, and can also re-run the detector that produced them: from the v0.9.1 tree, `tools/rescan_corpus.py -out <dir> -with-context` returns the same 476 findings, finding-for-finding against the committed export (re-verified 2026-09-07).

The test position moved with the release. Section 3 states that the pinned 0.8.0 detector’s 158-test suite is green across a 3 OS × 5 Python-version CI matrix. The 0.9.1 suite is larger — **221 tests** — and is green across that same matrix: on the release commit all 15 test jobs (Ubuntu, macOS and Windows × Python 3.9–3.13) passed, along with the quality job. Drafts written before the release reported 185 tests green on one operating system only and said the OS matrix could not be reached; both statements described the pre-release state and are superseded. The unit corpus moved too, and its version label is why we say so explicitly: at v0.8.0 it is v6 with 36 positive / 32 negative, while in the 0.9.1 tree the same label v6 denoted 34 / 34, because five narrow-type `contextlib.suppress` fixtures were relabelled as negatives when that rule was restricted to broad suppression and three moved the other way. One label denoting two different label sets is precisely the silent under-reproduction this section exists to prevent, so the corpus is now v7 and the label moves whenever the labels do. One limit does survive the release, because it is about the measurement rather than the test suite: every corpus scan reported in this paper was run on a single platform (macOS arm64). The CI matrix exercises the tests, not the scan.

One gap in the other direction has been closed rather than documented. `bench/corpus-coverage-union.json`, from which every RQ1 figure is read, used to record its own input as `/tmp/i1-scan` — a scratch directory no clone contains. It is now regenerated from `bench/rescan-f2/`, the same 621 findings committed in-tree, so the artefact and its input ship together; `bench/corpus-coverage-union-621frame.json` is the same run kept under a second name so that a reader who diffed the earlier file can still see it. Re-running `tools/coverage_union.py` with `-findings-dir bench/rescan-f2` reproduces 621 / 255 / 366 and every per-rule and per-tool cell of Tables 3 and 4.

```
git clone https://github.com/feiiiiii5/failroute && cd failroute
git checkout d14e020 # pinned commit: every artefact the tables use
python -m venv .venv && . .venv/bin/activate
pip install '[test,paper]' # pytest + matplotlib + 4 linters + bugbear
python tools/fetch_corpus.py # pinned sdists -> paper/corpus/
# version+sha256 pinned in paper/corpus-manifest.json; fetch verifies each
# archive against paper/corpus-lock.json and exits non-zero on mismatch
# (it rewrites only the lock's generated_at_utc timestamp; the eight
# archive digests are what must match)
PYTHONPATH=src python -m pytest # 158 tests
PYTHONPATH=src python tools/rescan_corpus.py --out bench/rescan-paper
# rescan with the current detector (total 621). Writes to bench/; do NOT
# re-export over paper/scan/, which is the frozen v0.7.0 baseline
python tools/coverage_union.py --findings-dir bench/rescan-f2
# -> bench/corpus-coverage-union.json ; union 255/621 = 41.1%
# bench/rescan-f2 is the committed 621-finding export the paper's figure
# was computed from; --findings-dir bench/rescan-paper (your own rescan)
# gives the same number. The default --findings-dir paper/scan is the
# frozen v0.7.0 set, whose union figure is deprecated.
python tools/coverage_union.py --ruff-select S110,S112,BLE001 \
--findings-dir bench/rescan-f2 --out /tmp/union-symmetric.json
# the symmetric baseline variant quoted in RQ1 (ruff also gets its
# broad-except rule): ruff 127 co-located, union 255/621 = 41.1% ---
# the same union the narrow selection gives, as RQ1 explains;
# committed as bench/corpus-coverage-union-ruff-ble001.json
python tools/make_figures.py # -> paper/figures/ (3 figures)
python tools/j1_adjudicate.py # diff-read family adjudication
python tools/compute_intervals.py # -> paper/intervals.json
```

Three further pipeline commands are deliberately *not* part of the reproduction path, because each overwrites a hand-curated artefact without regenerating it faithfully: `draw_sample.py` (the committed `paper/sample.jsonl` was drawn from the pre-fix 659 frame; re-drawing changes which 80 findings the published labels describe), `merged_pr_recall.py` (drops the hand-written note column), and

`compare_linters_corpus.py` (drops the merged semgrep results). See `paper/ARTIFACT.md` §0.2 and §5.5–5.6 before running any of them.

Key artefacts, and the thing each one pins down:

- `paper/corpus-lock.json` — pinned inputs.
- `paper/sample.jsonl` — the 80-item draw.
- `paper/annotations.csv` — labels and rationale.
- `paper/annotations-second-pass.csv` — second automated pass.
- `paper/merged-pr-recall.csv` — recall ground truth (all rows diff-read).
- `paper/j1-trulens2653-prefix.py` — pre-fix evidence for the `trulens#2653` detection.
- `bench/corpus-coverage-union-5tool.json` — cross-tool coverage including the self-written semgrep rule.
- `paper/intervals.json` — Wilson intervals.
- `paper/annotations-v2-additions.csv` — the 60 supplementary labels of Section 4.7, with rationale, enclosing signature, the detector’s own severity / isomorphism / `covered_by` values, and a flag for whether the site is new in the refactored frame. New file; the two frozen annotation files above are unchanged.
- `bench/corpus-coverage-per-finding-v2.jsonl` — the refactored 476-finding frame, one row per finding, carrying severity, isomorphism class and both novelty verdicts.
- `bench/corpus-coverage-union-v2.json` — the aggregate of that run: 476 findings, 252 covered, 224 failroute-only.
- `bench/corpus-coverage-per-finding-621.jsonl` — the same per-finding export for the v0.8.0 frame, regenerated from the in-tree `bench/rescan-f2/` so that RQ1 no longer depends on a scratch directory.
- `bench/corpus-coverage-union-621frame.json` — the aggregate of that run: 621 findings, 255 covered, 366 failroute-only, matching `bench/corpus-coverage-union.json` cell for cell.
- `bench/e722-baseline.json` — the E722 and BLE001 candidate counts and their overlap with the labelled defects.
- `bench/rq5-refactor-delta.json` — the frame difference and the label disposition under the refactor.
- `bench/intervals-v2.json` — every interval quoted in Section 4.7 and the two new RQ2 paragraphs, from the same canonical Wilson implementation as `paper/intervals.json`.
- `bench/lint-rule-mapping.json` — the measured matrix of which lint rule fires on which handler kind and body shape, from `tools/lint_mapping_probe.py`. This is the evidence the `covered_by` table is derived from rather than the table’s own assertion.
- `bench/corpus-coverage-per-finding-v2-pre-coverby-fix.jsonl` — the per-finding export as it stood *before* that correction. Preserved rather than regenerated: the over-crediting inference it records no longer exists in the source, so this file is the only record of what the earlier static-novelty figure of 18.3% was computed from, and the before/after comparison is a diff against it.
- `paper/h1_arm3_classification.csv` — the arm-3 closed-PR ledger (160 diff-read rows; 27 family), copied byte-identically from the companion repository.
- `paper/arm2-tracked-sites.csv` — the arm-2 tracked-site dataset: all 2,128 rows over the eight packages with all five labels, the version span and observation count each label rests on, and the PR each FIXED row is attributed to. Projected field-for-field from the companion repository’s maintainer-behaviour dataset; code snippets and commit-level attribution are deliberately excluded, so the labels are auditable but not re-derivable from this artefact alone.

Two things a reproducer must know.

1. The commands in this section all carry `PYTHONPATH=src`, and one of the reasons we used to give for that is wrong. This paragraph previously said an *editable* install fails when the checkout path contains non-ASCII characters because the generated `.pth` pointer is mangled. That was tested during the work behind Section 4.7 and does not reproduce: the path’s encoding, the build backend and `setuptools` are all irrelevant to it. What actually happened on the authors’ machine is that the `.pth` the editable install generated carried the macOS `UF_HIDDEN` BSD flag, and CPython’s `site.addpackage` (`site.py:176`) silently skips hidden files, so `import failroute` failed with no diagnostic pointing at the cause. Clearing the flag (`chflags nohidden`) fixed it; switching build backend did not. This is a property of one filesystem and not of the package, so a fresh clone on another machine will not have it — which is exactly why it is worth recording: the failure is silent and the plausible explanation is wrong. `PYTHONPATH=src` is correct before and after that fix and on

any machine, so the commands keep it.

2. The scanner exits with status 1 whenever it finds anything, even when the run succeeded and the export was written. Under `set -e` or in CI, a successful scan looks like a failure. The refactored detector of Section 4.7 replaces this with a severity gate (`-fail-on`, defaulting to `high`, plus `-exit-zero`), and exits 2 on an internal scan error; the behaviour described here is the pinned version’s.

Availability and ethics. The corpus is eight publicly distributed PyPI source distributions, each used under its own licence; nothing was taken from a private source. The maintainer-behaviour ground truth is a set of public GitHub issue and pull-request records, every one cited by its public number, and the two datasets derived from them are committed to the public repository and itemised in the list above, so that the classification can be audited row by row. The study analyses publicly recorded artefacts of professional work on public repositories, and uses no non-public data about identifiable individuals. The author’s conflict of interest — writing both the detector under evaluation and one of the five baselines — is disclosed on the title page, and the results unfavourable to the tool are reported alongside the favourable ones.

References

- [1] Saleema Amershi, Andrew Begel, Christian Bird, Robert DeLine, Harald Gall, Ece Kamar, Nachiappan Nagappan, Besmira Nushi, and Thomas Zimmermann. Software engineering for machine learning: A case study. In *2019 IEEE/ACM 41st International Conference on Software Engineering: Software Engineering in Practice (ICSE-SEIP)*, pages 291–300, 2019. doi: 10.1109/ICSE-SEIP.2019.00042.
- [2] Nathaniel Ayewah and William Pugh. The google findbugs fixit. In *Proceedings of the 19th international symposium on Software testing and analysis*, pages 241–252, 2010. doi: 10.1145/1831708.1831738.
- [3] Guilherme Bicalho de Pádua and Weiyi Shang. Revisiting exception handling practices with exception flow analysis. In *2017 IEEE 17th International Working Conference on Source Code Analysis and Manipulation (SCAM)*, pages 11–20, 2017. doi: 10.1109/SCAM.2017.16.
- [4] Guilherme Bicalho de Pádua and Weiyi Shang. Studying the prevalence of exception handling anti-patterns. In *2017 IEEE/ACM 25th International Conference on Program Comprehension (ICPC)*, pages 328–331, 2017. doi: 10.1109/ICPC.2017.1.
- [5] Eric Breck, Shanqing Cai, Eric Nielsen, Michael Salib, and D. Sculley. The ml test score: A rubric for ml production readiness and technical debt reduction. In *2017 IEEE International Conference on Big Data (Big Data)*, pages 1123–1132, 2017. doi: 10.1109/BigData.2017.8258038.
- [6] Bruno Cabral and Paulo Marques. Exception handling: A field study in java and .net. In *ECOOP 2007 — Object-Oriented Programming*, Lecture Notes in Computer Science, pages 151–175. Springer Berlin Heidelberg, Berlin, Heidelberg, 2007. doi: 10.1007/978-3-540-73589-2_8.
- [7] Anamaria Crisan and Andrew M McNutt. Linting is people! exploring the potential of human computation as a sociotechnical linter of data visualizations. In *Proceedings of the Extended Abstracts of the CHI Conference on Human Factors in Computing Systems*, pages 1–10, 2025. doi: 10.1145/3706599.3716230.
- [8] Harish Dixit. Keytone: Silent data corruptions at scale. In *2023 IEEE 29th International Symposium on On-Line Testing and Robust System Design (IOLTS)*, pages 1–2, 2023. doi: 10.1109/IOLTS59296.2023.10224872. Two-page keynote abstract; title reproduced exactly as registered by IEEE, where “Keytone” is a typographical error for “Keynote”.
- [9] Lisa Nguyen Quang Do, James R. Wright, and Karim Ali. Why do software developers use static analysis tools? a user-centered study of developer needs and motivations. *IEEE Transactions on Software Engineering*, 48:835–847, 2022. doi: 10.1109/TSE.2020.3004525.
- [10] Zhaoqiang Guo, Tingting Tan, Shiran Liu, Xutong Liu, Wei Lai, Yibiao Yang, Yanhui Li, Lin Chen, Wei Dong, and Yuming Zhou. Mitigating false positive static analysis warnings: Progress,

challenges, and opportunities. *IEEE Transactions on Software Engineering*, 49:5154–5188, 2023. doi: 10.1109/TSE.2023.3329667.

- [11] Huimin Hu, Yingying Wang, Julia Rubin, and Michael Pradel. An empirical study of suppressed static analysis warnings. *Proceedings of the ACM on Software Engineering*, 2:290–311, 2025. doi: 10.1145/3715729.
- [12] Brittany Johnson, Yoonki Song, Emerson Murphy-Hill, and Robert Bowdidge. Why don’t software developers use static analysis tools to find bugs? In *2013 35th International Conference on Software Engineering (ICSE)*, pages 672–681, 2013. doi: 10.1109/ICSE.2013.6606613.
- [13] Andrei Paleyes, Raoul-Gabriel Urma, and Neil D. Lawrence. Challenges in deploying machine learning: A survey of case studies. *ACM Computing Surveys*, 55:1–29, 2022. doi: 10.1145/3533378.
- [14] Neoklis Polyzotis, Martin Zinkevich, Sudip Roy, Eric Breck, and Steven Whang. Data validation for machine learning. In *Proceedings of the Machine Learning and Systems Conference (MLSys) 2019*, 2019. URL https://proceedings.mlsys.org/paper_files/paper/2019/hash/928f1160e52192e3e0017fb63ab65391-Abstract.html.
- [15] Louis-Philippe Querel and Peter C. Rigby. Warningsguru: integrating statistical bug models with static analysis to provide timely and specific bug warnings. In *Proceedings of the 2018 26th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*, pages 892–895, 2018. doi: 10.1145/3236024.3264599.
- [16] Joseph R. Ruthruff, John Penix, J. David Morgenthaler, Sebastian Elbaum, and Gregg Rothermel. Predicting accurate and actionable static analysis warnings. In *Proceedings of the 30th international conference on Software engineering*, pages 341–350, 2008. doi: 10.1145/1368088.1368135.
- [17] Caitlin Sadowski, Jeffrey Van Gogh, Ciera Jaspan, Emma Soderberg, and Collin Winter. Tricorder: Building a program analysis ecosystem. In *2015 IEEE/ACM 37th IEEE International Conference on Software Engineering*, pages 598–608, 2015. doi: 10.1109/ICSE.2015.76.
- [18] Caitlin Sadowski, Edward Aftandilian, Alex Eagle, Liam Miller-Cushon, and Ciera Jaspan. Lessons from building static analysis tools at google. *Communications of the ACM*, 61:58–66, 2018. doi: 10.1145/3188720.
- [19] Nithya Sambasivan, Shivani Kapania, Hannah Highfill, Diana Akrong, Praveen Paritosh, and Lora M Aroyo. “everyone wants to do the model work, not the data work”: Data cascades in high-stakes ai. In *Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems*, pages 1–15, 2021. doi: 10.1145/3411764.3445518.
- [20] Puntitra Sawadpong, Edward B. Allen, and Byron J. Williams. Exception handling defects: An empirical study. In *2012 IEEE 14th International Symposium on High-Assurance Systems Engineering*, pages 90–97, 2012. doi: 10.1109/HASE.2012.24.
- [21] D. Sculley, Gary Holt, Daniel Golovin, Eugene Davydov, Todd Phillips, Dietmar Ebner, Vinay Chaudhary, Michael Young, Jean-François Crespo, and Dan Dennison. Hidden technical debt in machine learning systems. In *Advances in Neural Information Processing Systems 28 (NeurIPS 2015)*, 2015. URL https://proceedings.neurips.cc/paper_files/paper/2015/hash/86df7dcfd896fcacf2674f757a2463eba-Abstract.html.
- [22] Rahul Yedida, Hong Jin Kang, Huy Tu, Xueqi Yang, David Lo, and Tim Menzies. How to find actionable static analysis warnings: A case study with findbugs. *IEEE Transactions on Software Engineering*, 49:2856–2872, 2023. doi: 10.1109/TSE.2023.3234206.
- [23] Jie M. Zhang, Mark Harman, Lei Ma, and Yang Liu. Machine learning testing: Survey, landscapes and horizons. *IEEE Transactions on Software Engineering*, 48:1–36, 2022. doi: 10.1109/TSE.2019.2962027.